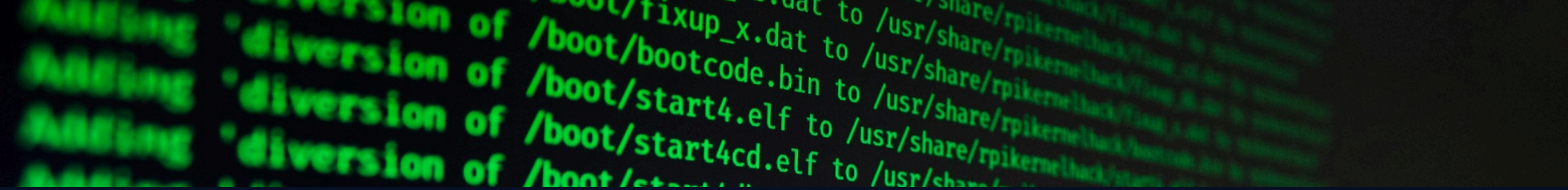
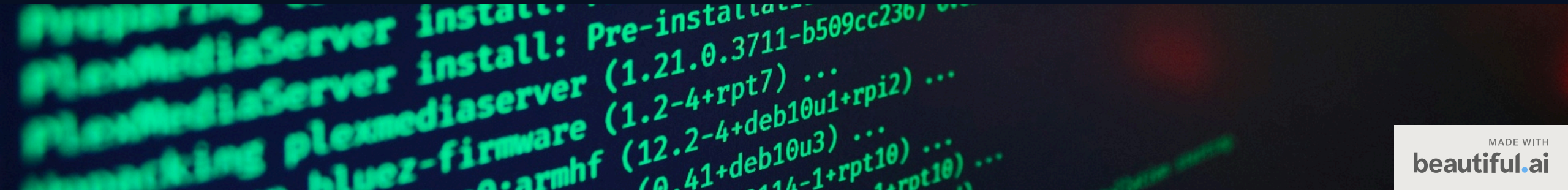


IS THAT SQL INJECTION IN YOUR REPORT?

Slide Deck



MADE WITH beautiful.ai

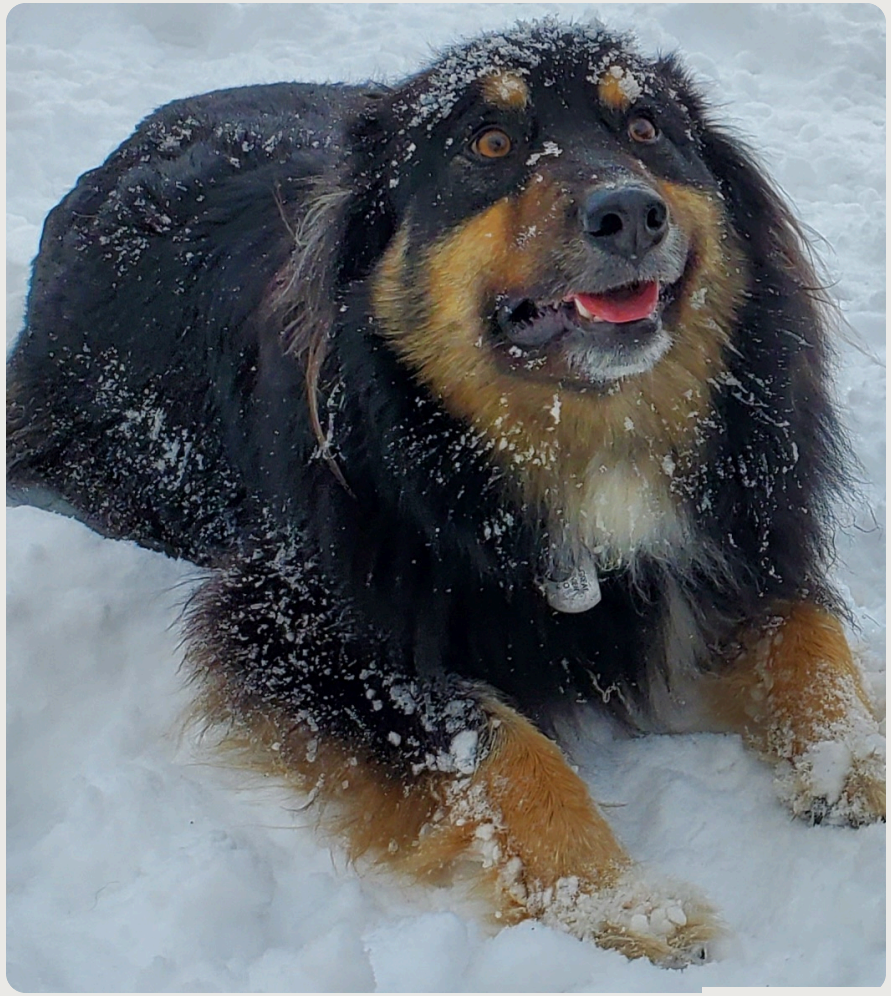
COURTNEY COOKSEY

Software Engineer

The Crossing, EPC

COLUMBIA, MO

Savannah, MO



Slide Deck

MADE WITH beautiful.ai

AGENDA

1. Rock Security 101 & Security Settings
2. Account Takeover Attack
3. Pitfalls with Impersonation Tokens
4. Person Merge Attack
5. Injection Attack
6. How You can Protect Your System

MADE WITH beautiful.ai

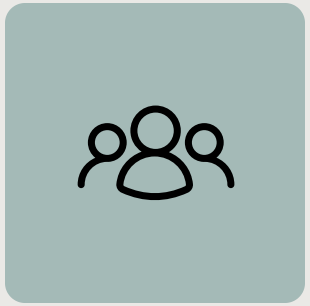
ROCK SECURITY 101

Slide Deck

PERSON RECORDS, SECURITY GROUPS, AND USER LOGINS

MADE WITH
beautiful.ai

THERE ARE TWO MAIN ENTITIES INVOLVED IN AUTHENTICATION



Person Entity

Rules for **what** someone can access is tied to their person record.

User Login Entity

Used to verify that a specific person record belongs to you.

MADE WITH beautiful.ai

PERMISSIONS ARE ADDED BY GROUP OR PERSON

Item Permissions

No role/users Found

Add Role | Add User

Inherited Permissions

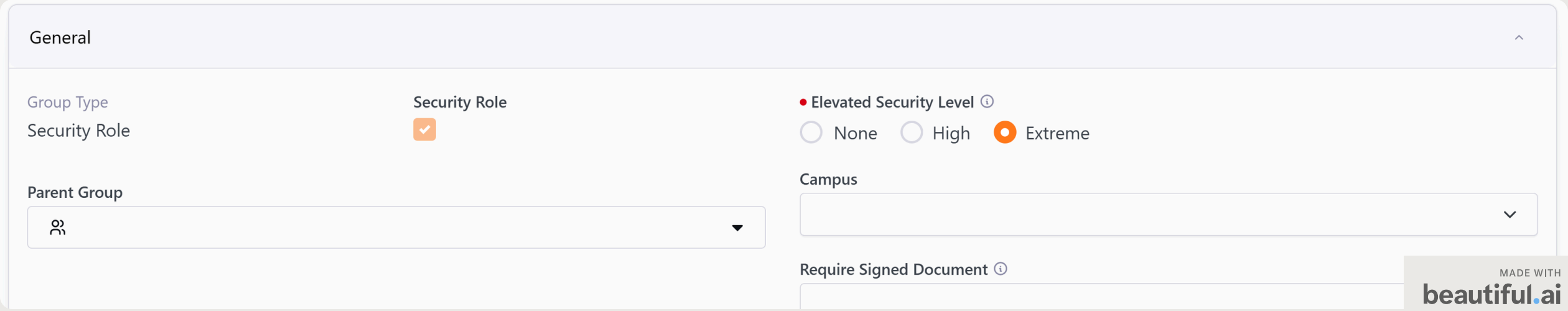
Role / User	Action	From
RSR - Rock Administration (Role)	Allow	Rock RMS (Site)
RSR - Staff Workers (Role)	Allow	Rock RMS (Site)
RSR - Staff Like Workers (Role)	Allow	Rock RMS (Site)
All Users	Deny	Rock RMS (Site)

MADE WITH beautiful.ai

SECURITY GROUPS ARE JUST GROUPS

GROUPS LISTED IN SETTINGS > SECURITY > SECURITY ROLES ARE NOT A DIFFERENT ENTITY

- Their Group Type is "Security Role"
- The "Security Role" checkbox is checked
- You have the option to indicate the group should elevate the "Protection Profile" of its members



MADE WITH beautiful.ai

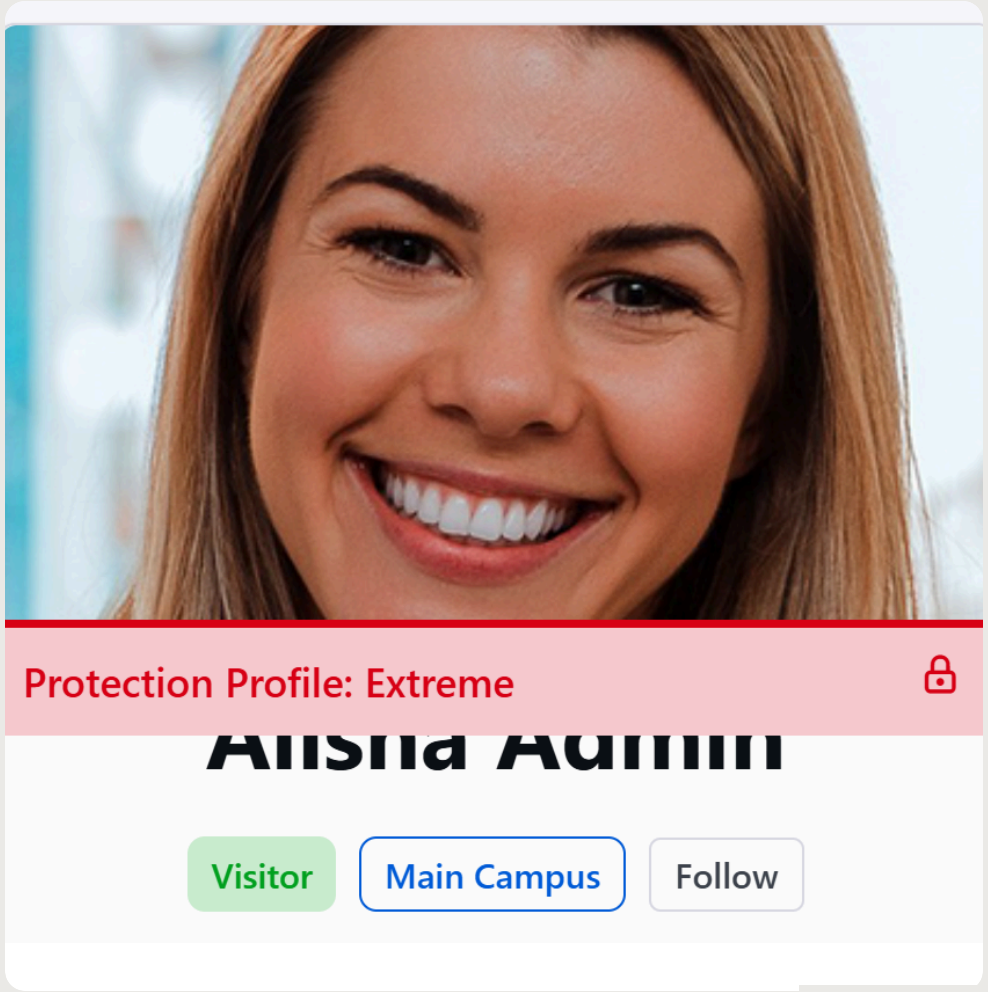
PROTECTION PROFILES DEMONSTRATE ACCESS TO ROCK

1. **Low**
   No risk items

2. **Medium**
   Has login account

3. **High**
   Active Scheduled Financial Transaction
   Saved Payment Account
   In a Security Role marked w/ High Elevated Security

4. **Extreme**
   In a Security Role marked w/ Extreme Elevated Security



MADE WITH
beautiful.ai

SECURITY SETTINGS FOR PROTECTION PROFILES

ADMIN TOOLS > SETTINGS > SECURITY > SECURITY SETTINGS

Disable Duplicate Checking for the Following Protection Profiles

- [ ] Low
- [x] Medium
- [x] High
- [x] Extreme

Allow Merges of Account Protection Profile - High

RSR - Data Integrity Worker

Disable Usage of Personal Tokens for the Following Protection Profiles

- [ ] Low
- [ ] Medium
- [ ] High
- [x] Extreme

MADE WITH beautiful.ai

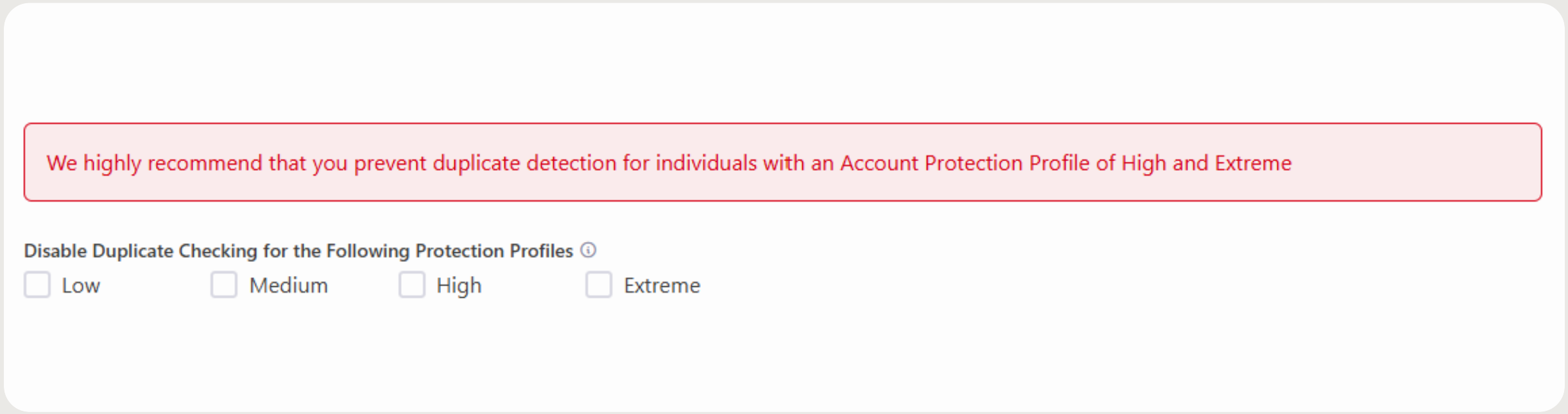
Slide Deck

ACCOUNT TAKEOVER ATTACK

WHAT HAPPENS WHEN YOU ENABLE DUPLICATE CHECKING

MADE WITH
beautiful.ai

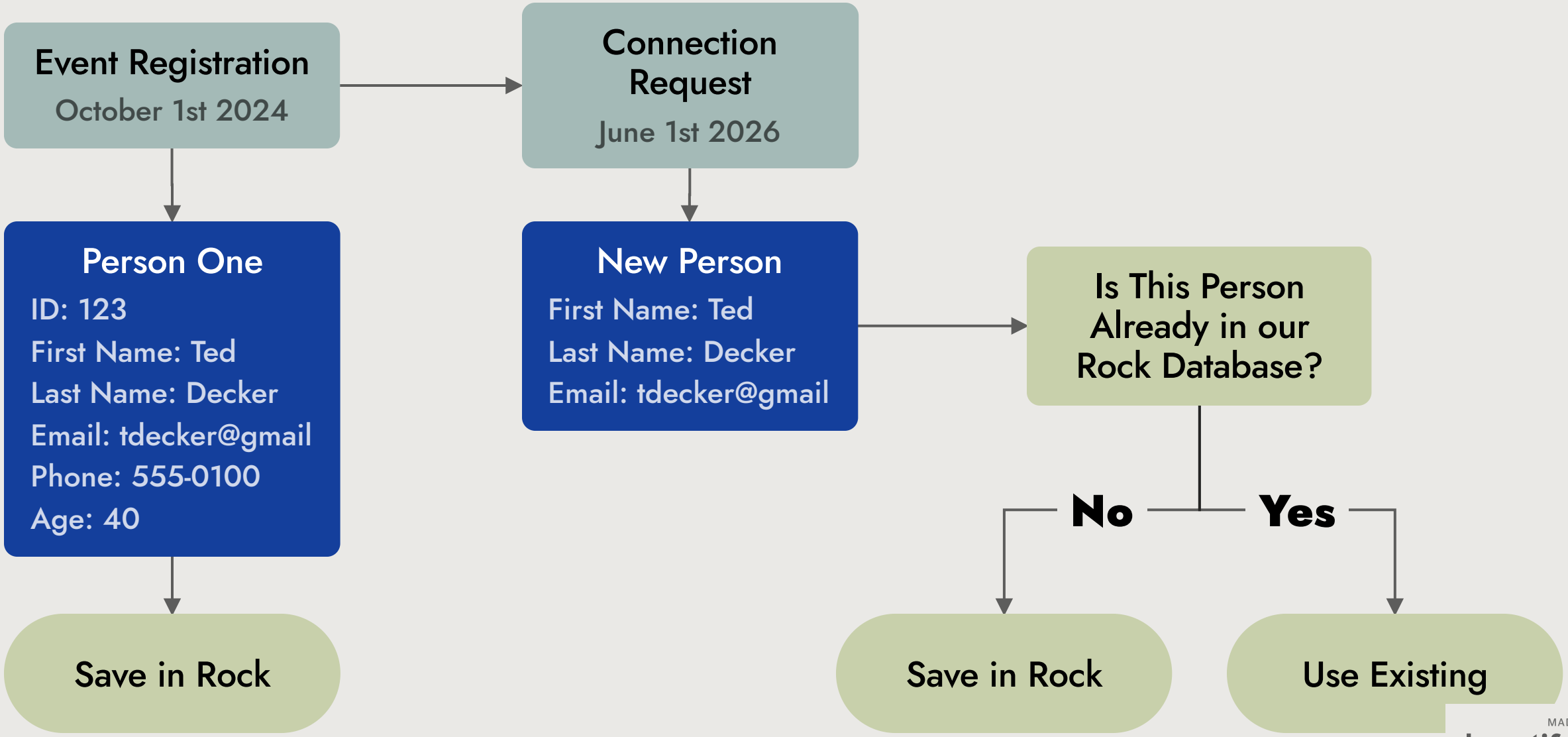
SECURITY SETTINGS FOR EXAMPLE



Rock warns us because this configuration will let a bad actor easily take control of a staff member's account

MADE WITH beautiful.ai

DUPLICATE CHECKING IS ROCK'S AUTOMATIC DATA CLEANING MECHANISM



MADE WITH beautiful.ai

ROCK'S MATCHING EQUATION

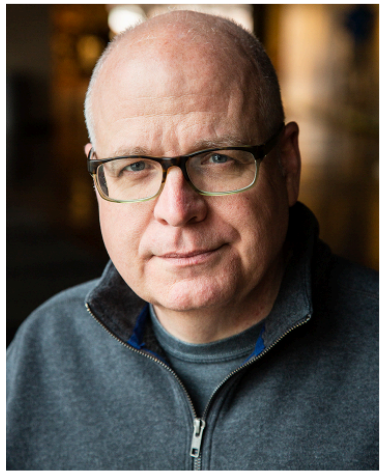
35+ Points Matches a Record

First Name/Nick Name Matched	+15
Last Name Matched	+15
Last Name NOT Matched, Previous Name Matched	+12
Mobile, Primary Email, or Previous Email Matched	+15
Birth Date Matched	+10
Birth Date Year Matched	+5
Gender Matched	+3
Suffix Matched	+10

MADE WITH beautiful.ai

YOUR STAFF'S NAMES AND EMAILS ARE NOT SECRET

name@website



Dave Cover

Keith Simon

Kyle Richter

COMMUNITY PASTOR

Greg McElfresh

Greg is the Oakley Community Pastor. After launching both the West Side and East Side sites in Cincinnati, he is thrilled to be back where his Crossroads journey began. Greg is an avid lawn-striper, National Park hiker, and bonfire and bourbon sipper. He and his wife Abby have three girls: Emme, Liv, and Ada.

I'D LOVE TO CONNECT WITH YOU.

Email me

Follow Greg Follow Greg

Lead Pastors

Brad Cooper

Lead Pastor of Culture & Direction

Contact Brad

Riley Cummings

Lead Pastor of Campuses

Contact Riley

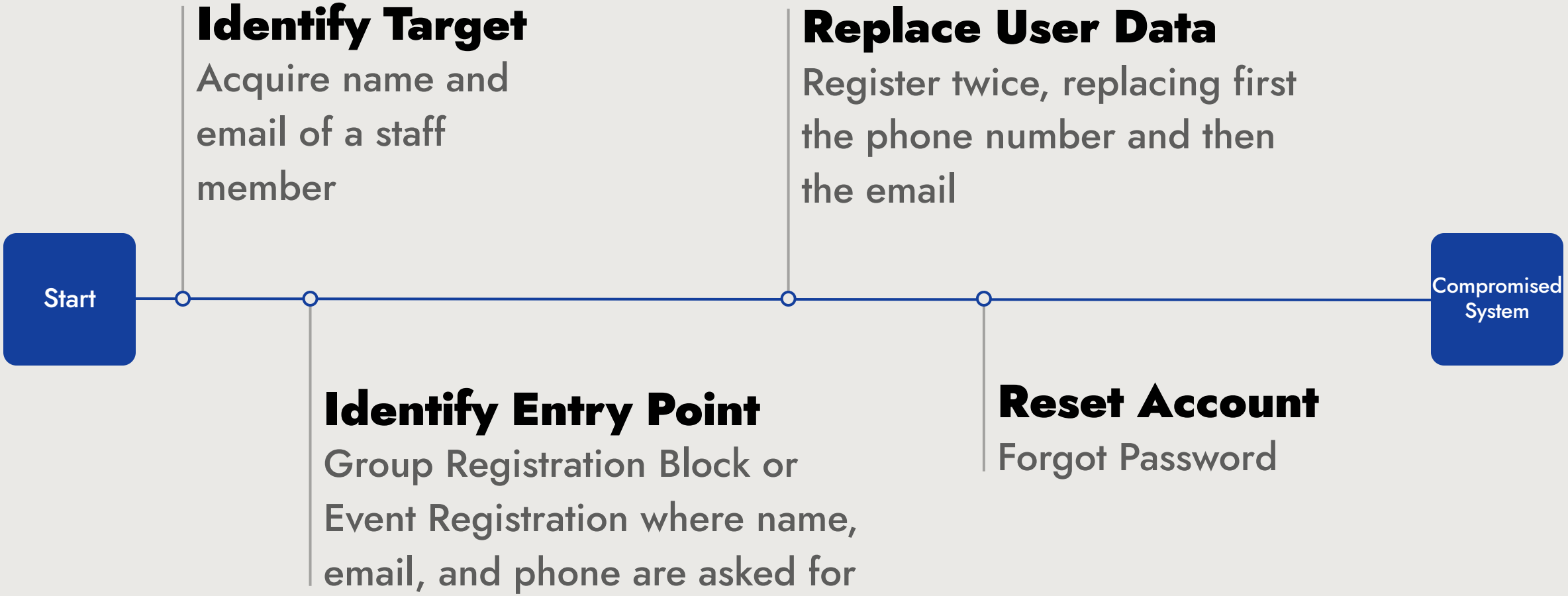
David Hall

Lead Pastor of Ministries

Contact David

MADE WITH beautiful.ai

TIMELINE OF ATTACK FOR ACCOUNT TAKEOVER



MADE WITH beautiful.ai

Crossing Twenties - Group Registration

Please complete the form below to register for Choi (Ben) & Butcher (Brian) Small Group.

• First Name

Dave

• Last Name

Cover

Mobile Phone

1 ▾ (555) 555-0100

Give your consent to receive SMS messages by simply checking the box.

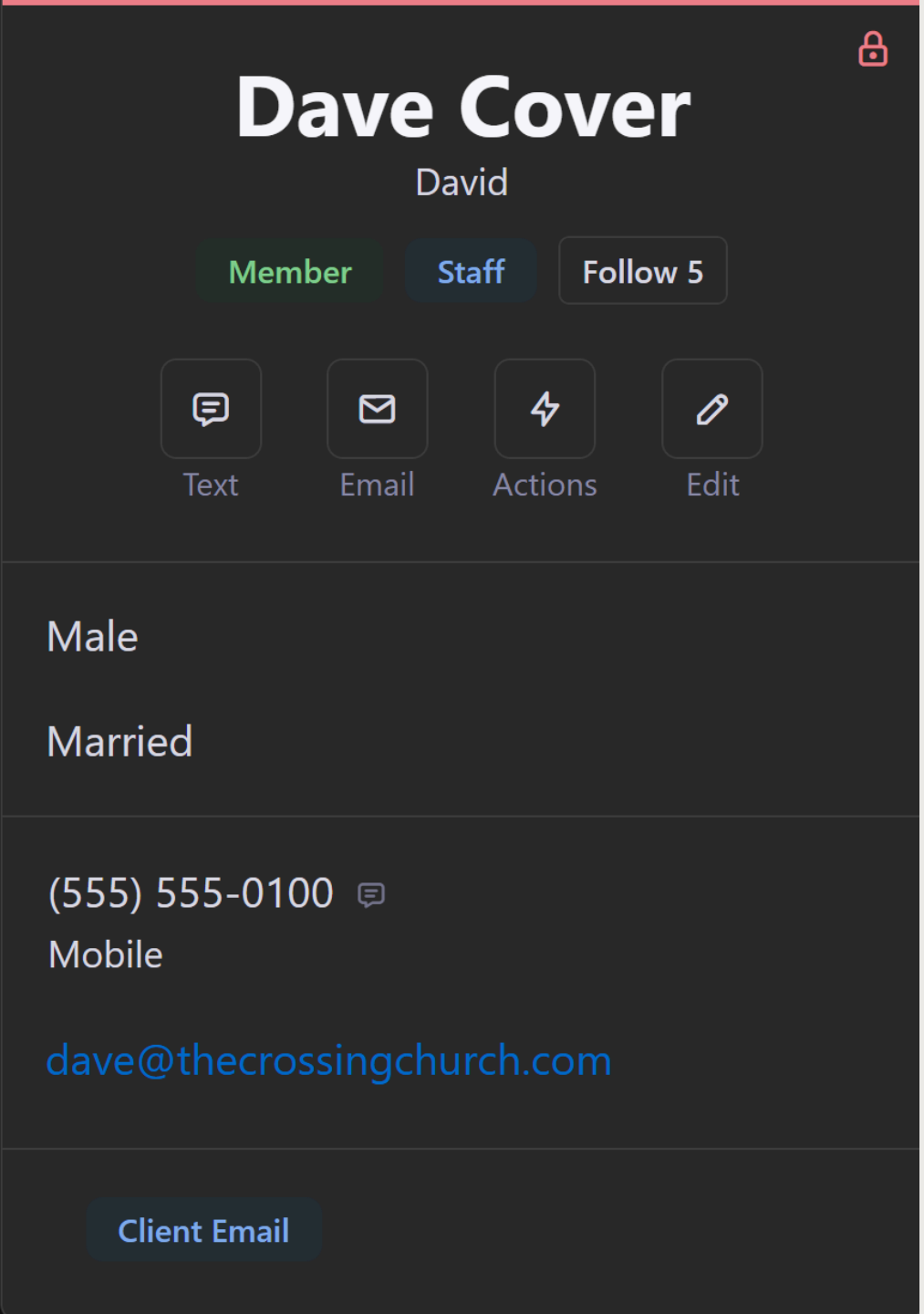
• Email

dave@thecrossingchurch.com

Home Phone

1 ▾

MADE WITH beautiful.ai



CONFIRM PHONE NUMBER UPDATE

Nick Name	"Dave"	+15
Last Name	"Cover"	+15
Email	"dave@tcc.com"	+15

45

MADE WITH beautiful.ai

Crossing Twenties - Group Registration

Please complete the form below to register for Choi (Ben) & Butcher (Brian) Small Group.

• First Name

Dave

• Last Name

Cover

Mobile Phone

1 ▾ (555) 555-0100

☐ Give your consent to receive SMS messages by simply checking the box.

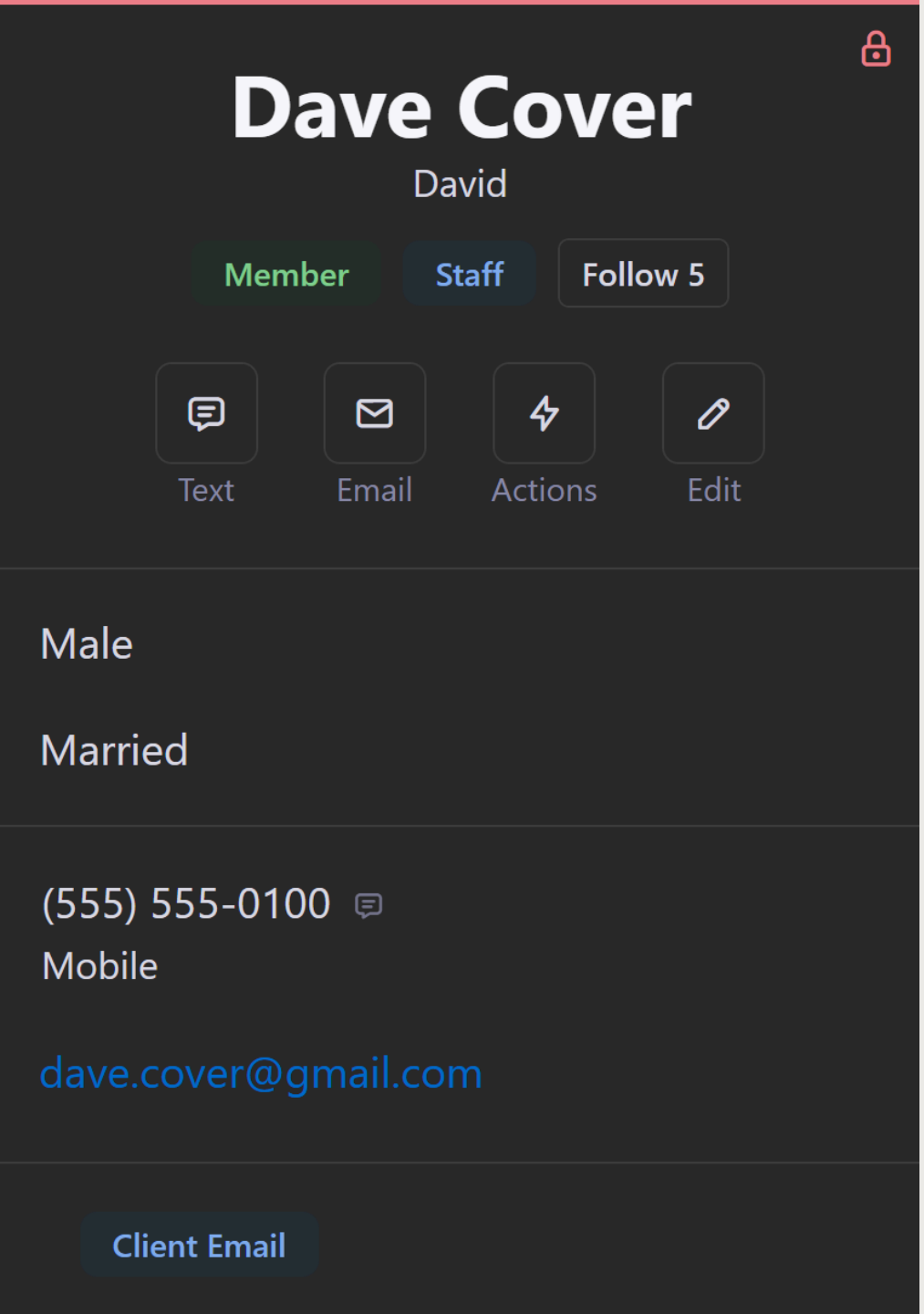
• Email

dave.cover@gmail.com

Home Phone

1 ▾

MADE WITH beautiful.ai

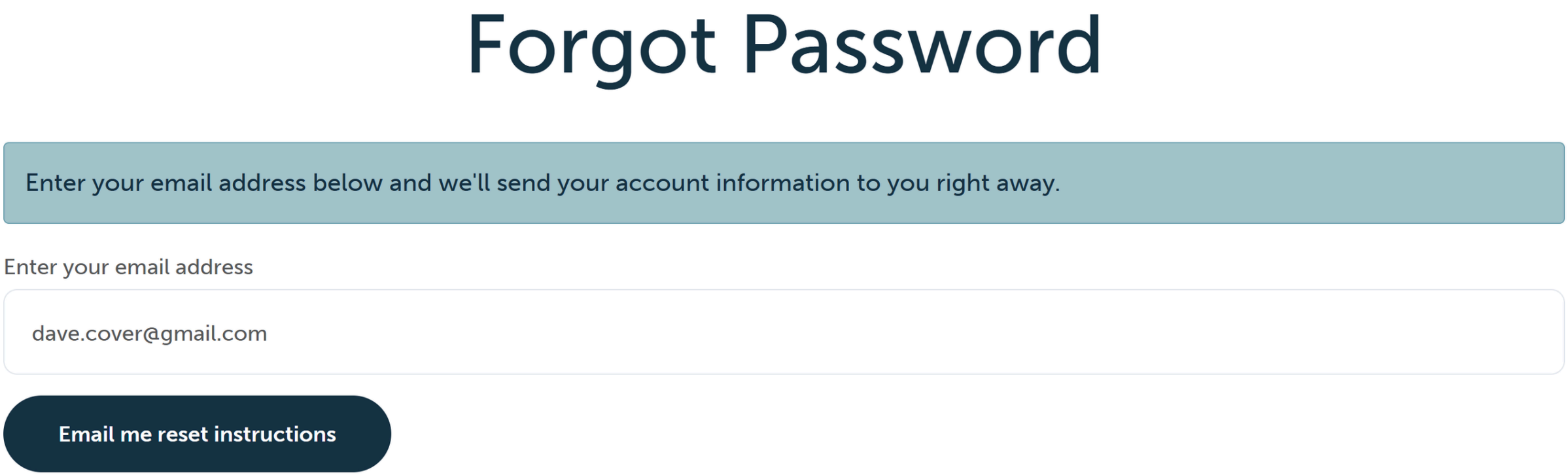


CONFIRM EMAIL UPDATE

Nick Name "Dave"	+15
Last Name "Cover"	+15
Phone "555-0100"	+15
	45

MADE WITH beautiful.ai

NOW THE EMAIL/PHONE ARE OURS WE CAN RESET THE ACCOUNT



MADE WITH beautiful.ai

THE crossing

Below are your current usernames at The Crossing

Username: pastordave

Reset Password

The Crossing
3615 Southland Dr.
Columbia, MO 65201

MADE WITH beautiful.ai

Account Confirmation

David, enter a new password for your 'pastordave' account.

Enter New Password

• New Password

• Confirm Password

Change Password

MADE WITH beautiful.ai

Log In

Log In

Username

pastordave

Password

••••••••••••

Keep me logged in

Log In | Create New Account | Forgot Account

MADE WITH beautiful.ai

Dave Cover

Male
Married

Contact Information

Home Address
3615 Southland Dr
Columbia, MO 65201-5426

Email
dave.cover@gmail.com

Update Profile

Cover Family

Jeannette Cover

Female

Contact Info

Account Info

Change Password

Giving

You currently have no active profiles.

Manage Giving

View History

Give Now

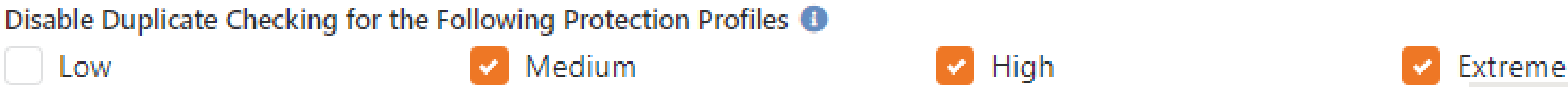
Groups

Cover (Dave &

MADE WITH beautiful.ai

PREVENT ACCOUNT TAKEOVER ATTACKS

- Disable Duplicate Checking for **any** Protection Profile associated with a user login
  Medium, High, Extreme
- Ensure anyone with access to your internal Rock site has a **High** or **Extreme** Protection Profile
- Audit changes to contact information
- Require users to login before submitting forms



MADE WITH beautiful.ai

PITFALLS WITH IMPERSONATION TOKENS

Slide Deck

WHAT HAPPENS WHEN YOU ENABLE TOKENS FOR STAFF

MADE WITH
beautiful.ai

THERE ARE TWO TYPES OF PERSON TOKENS

IMPERSONATION TOKENS

- Used to fully replicate the authentication of another person
- Created via Lava Filter
  PersonImpersonationToken
  PersonTokenCreate
- Accessed from Profile
  Actions > Impersonate

ACTION IDENTIFIERS

- Used to identify a person for a single action on your site
- Created via Lava Filter
  PersonActionIdentifier
- Used for Single Access to
  RSVP
  Assessments
  Communication Unsubscribe
  Contribution Statements

MADE WITH beautiful.ai

ANATOMY OF AN IMPERSONATION TOKEN

```
{{ Person | PersonTokenCreate:Minutes, MaxUsage, PageId }}
```

- **Minutes (Optional)**
  The number of minutes this token is valid
- **Max Usage (Optional)**
  The maximum number of times this token can be used
- **Page Id (Optional)**
  A single page to limit this token to

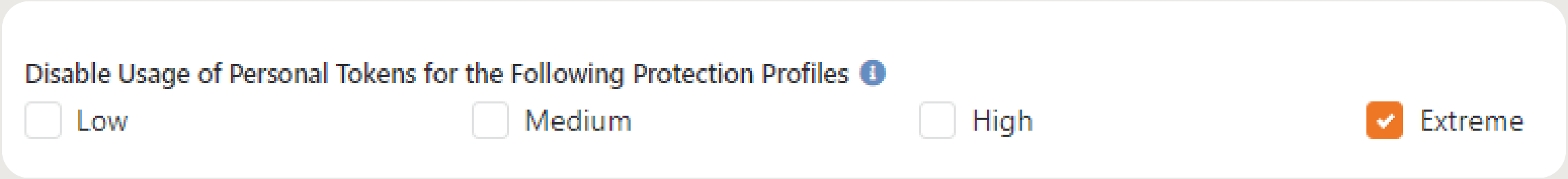
MADE WITH
beautiful.ai

IMPERSONATION TOKEN WARNINGS

- Leaving all Parameters Blank Fully Authorizes as that Person on Your Entire Site, Forever
- Options only apply to new sessions
  They will not impact previously established sessions
- Recommended to never create an impersonation token without a Page Id and some kind of usage limit

MADE WITH beautiful.ai

LET'S ASSUME WE HAVE TOKENS DISABLED FOR EXTREME PROFILES



MADE WITH
beautiful.ai

ACCESSING A TOKEN FOR AN EXTREME PROFILE DOESN'T SKIP

Group Attendance Reminders

```
Please remember to enter attendance for your group meeting.
{{ 'Global' | Attribute:'PublicApplicationRoot' }}page/368?
{{ Person.ImpersonationParameter }}&GroupId={{ Group.Id
}}&Occurrence={{ Occurrence | Date:'yyyy-MM-
ddTHH\%3amm\%3ass' }}
```

MADE WITH beautiful.ai

ACCESSING A TOKEN FOR AN EXTREME PROFILE DOESN'T SKIP

Group Attendance Reminders

```
Please remember to enter attendance for your group meeting.
{{ 'Global' | Attribute:'PublicApplicationRoot' }}page/368?
{{ Person.ImpersonationParameter }}&GroupId={{ Group.Id
}}&Occurrence={{ Occurrence | Date:'yyyy-MM-
ddTHH\%3amm\%3ass' }}
```

https://rock.mychurch.com/page/368?rckipid=TokenProhibited

MADE WITH beautiful.ai

FIX BAD USER EXPERIENCE BY CONDITIONALLY ADDING TOKENS

```
{% if Person.AccountProtectionProfile != 'Extreme' %}{%
endif %}
```

MADE WITH
beautiful.ai

FIX BAD USER EXPERIENCE BY CONDITIONALLY ADDING TOKENS

```
{% if Person.AccountProtectionProfile != 'Extreme' %}{%
endif %}
```

```
Please remember to enter attendance for your group meeting.
{{ 'Global' | Attribute:'PublicApplicationRoot' }}page/368?
{% if Person.AccountProtectionProfile != 'Extreme' %}{{
Person | PersonTokenCreate:10080,5,368 }}{% endif
%}&GroupId={{ Group.Id }}&Occurrence={{ Occurrence |
Date:'yyyy-MM-ddTHH\%3amm\%3ass' }}
```

MADE WITH
beautiful.ai

FIX BAD USER EXPERIENCE BY CONDITIONALLY ADDING TOKENS

```
{% if Person.AccountProtectionProfile != 'Extreme' %}{%
endif %}
```

```
Please remember to enter attendance for your group meeting.
{{ 'Global' | Attribute:'PublicApplicationRoot' }}page/368?
{% if Person.AccountProtectionProfile != 'Extreme' %}{{
Person | PersonTokenCreate:10080,5,368 }}{% endif
%}&GroupId={{ Group.Id }}&Occurrence={{ Occurrence |
Date:'yyyy-MM-ddTHH\%3amm\%3ass' }}
```

https://rock.mychurch.com/page/368?GroupId=123&OccurrenceDate=2026-10-01

MADE WITH beautiful.ai

ANATOMY OF AN ACTION IDENTIFIER

```
{{ Person | PersonActionIdentifier: 'action' }}
```

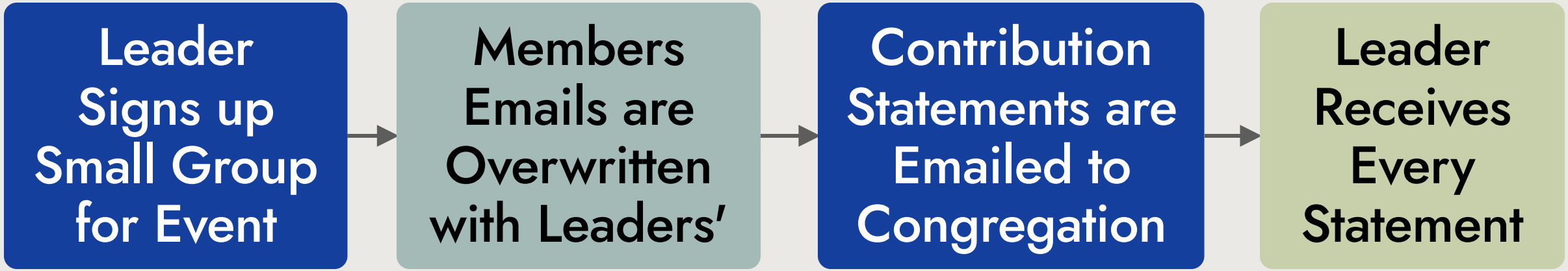
- **Action**
  The name of the specific action we are identifying this user for ('RSVP')

- Does not authenticate as this person
- Only supplies an existing Person to associate with the action

MADE WITH
beautiful.ai

ACTION IDENTIFIER WARNINGS

- Using an action identifier doesn't protect against bad data
- Emails are not unique



MADE WITH beautiful.ai

Slide Deck

PERSON MERGE ATTACKS

WAYS YOUR STAFF CAN GRANT ELEVATED ACCESS TO BAD ACTORS

MADE WITH
beautiful.ai

MERGE ATTACKS ARE FAIRLY SIMPLE

FAKE ACCOUNT IS CREATED

Bad actors use regular features of your Rock instance to create a new account that **looks** like it belongs to someone else.

ACCESS IS EXPLOITED

Bad actor uses their new access to do nefarious things

RECORDS ARE MERGED

Someone on your staff accidentally merges the fake and real accounts

MADE WITH beautiful.ai

SELECTING A TARGET

- Information is Key
- First target to gain entry to the system might not be someone we think has RSR - Admin rights, but someone we can find public information on
- Using their credentials we can learn more and gain access to other users/roles with higher clearance

MADE WITH
beautiful.ai

HACKERS DON'T NEED TO USE THE DARK WEB TO GET YOUR INFO

- Your Church's Staff Bios
- Social Media (Facebook, Instagram, LinkedIn)
- Public GIS Data
- School Information (Athletics, Honor Rolls, etc)
- Obituaries, Wedding Websites
- Information Brokers

MADE WITH
beautiful.ai

Brian Cooksey

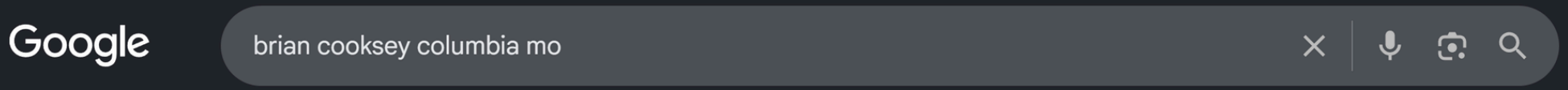
Operations Manager

Brian serves part-time as the operations manager and a leader coach for Crossing Men. He is passionate about helping people experience the life transformation that comes through following Jesus and being in community with others.

Brian grew up in Columbia. He graduated from Mizzou in 2009 and has worked in the software industry ever since. He received a graduate degree from Covenant Theological Seminary in St. Louis in 2024. Brian has served in the men's ministry at the Crossing for many years.

Brian married his high school sweetheart, Beka. They have three kids.

MADE WITH beautiful.ai



AI Mode | **All** | Images | News | Forums | Videos | Shopping | More | Tools

LinkedIn · Brian Cooksey
580+ followers

Brian Cooksey - Director of Engineering at Zapier

United States · Director of Engineering (Technical Foundations) · Zapier
Director of Engineering at Zapier · Experience: Zapier · Education: University of Missouri-Columbia · Location: United States · 500+ connections on LinkedIn ...

thecrossingchurch.com
https://my.thecrossingchurch.com › Staff

Crossing Men | The Crossing in Columbia, MO

He and Nicole have a daughter and two sons. **Brian Cooksey**. Operations Manager ... Brian grew up in **Columbia**. He graduated from Mizzou in 2009 and has ... Read more

The Guam Daily Post
https://www.postguam.com › Business › World Business

As baby leaves go gender-neutral, dads get time off

Feb 18, 2025 — ?!'" says **Cooksey, 30, who has three children, ages 11, five and 13 months** and lives in Columbia, Missouri. After his second child was born ... Read more

Zapier
https://zapier.com › blog › author › brian-cooksey

Brian Cooksey

Brian Cooksey is the **Director of Engineering at Zapier** and a Missouri native.

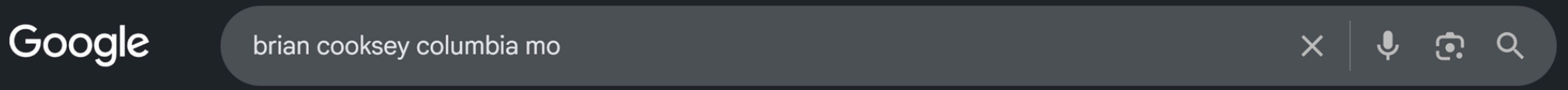
MADE WITH beautiful.ai

Brian Cooksey

Brian Cooksey is the Director of Engineering at Zapier and a Missouri native.

Brian's articles

MADE WITH beautiful.ai



AI Mode | **All** | Images | News | Forums | Videos | Shopping | More | Tools

LinkedIn · Brian Cooksey
580+ followers

Brian Cooksey - Director of Engineering at Zapier

United States · Director of Engineering (Technical Foundations) · Zapier
Director of Engineering at Zapier · Experience: Zapier · Education: University of Missouri-Columbia · Location: United States · 500+ connections on LinkedIn ...

thecrossingchurch.com
https://my.thecrossingchurch.com › Staff

Crossing Men | The Crossing in Columbia, MO

He and Nicole have a daughter and two sons. **Brian Cooksey**. Operations Manager ... Brian grew up in **Columbia**. He graduated from Mizzou in 2009 and has ... Read more

The Guam Daily Post
https://www.postguam.com › Business › World Business

As baby leaves go gender-neutral, dads get time off

Feb 18, 2025 — ?!'" says **Cooksey, 30, who has three children, ages 11, five and 13 months** and lives in Columbia, Missouri. After his second child was born ... Read more

Zapier
https://zapier.com › blog › author › brian-cooksey

Brian Cooksey

Brian Cooksey is the **Director of Engineering at Zapier** and a Missouri native.

MADE WITH beautiful.ai

As baby leaves gc time off

REUTERS
SEP 20, 2016

REUTERS
SEP 20, 2016 UPDATED FEB 18, 2025

A father holds up his son for a photo in front of a cherry tree in full blossom in Central Park in New York on April 20, 2014. Reuters

When Brian Cooksey j
benefits package, espe

Cooksey, 30, who has three children, ages 11, five and 13 months and lives in Columbia, Missouri.

And when Cooksey became the first employee at Zapier to expect a child, management came to him for feedback on what the policy should be.

"They said, 'We're looking at 14 weeks of paid leave, what do you think?,' I remember thinking, 'Do they really mean weeks?!'" says Cooksey, 30, who has three children, ages 11, five and 13 months and lives in Columbia, Missouri.

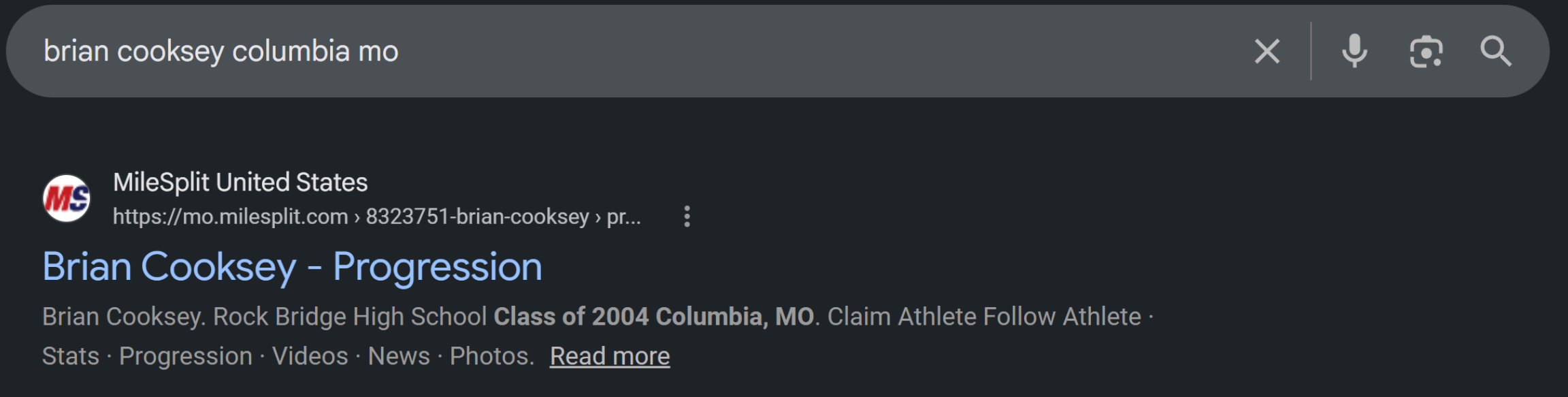
After his second child was born, his previous employer only gave him 14 days of parental leave.

What changed in the meantime time was a key decision by the U.S. Equal Employment Opportunity Commission in 2014 that mandated all leaves be treated the same, beyond the birth of a child qualifying for

Parental Leave Article

- Sep 20th, 2016
- 30 - Born Sep 1985 - Dec 1986
- 11 year old - Born Sep 2004 - Dec 2005
  Should be ~21/22 in 2026
- 5 year old - Born Sep 2010 - Dec 2011
  Should be ~15/16 in 2026
- 13 month old - Born Aug, 2015
  Should be ~11 in 2026

MADE WITH beautiful.ai



High School Graduation Year of 2004 for Rock Bridge

MADE WITH beautiful.ai

maps.boonemo.gov/viewers/AS_ParcelMapping_v1/

Parcel Information Viewer

Parcel Number, Owner's Name, or Property Address:

Search...

Zoom to Neighborhood | Zoom to Location | Print | Link | Map Legend | Help

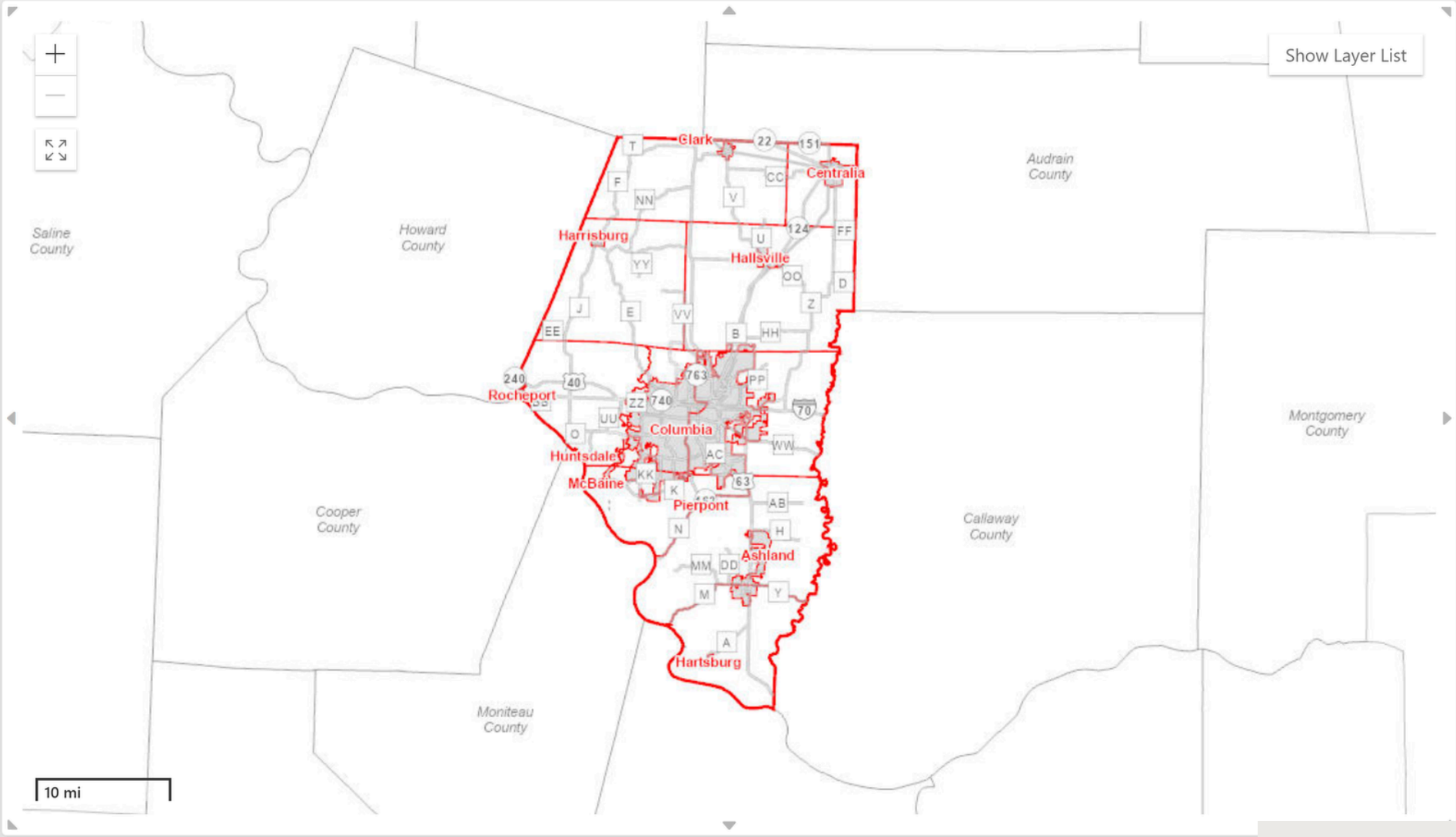
Welcome to the Boone County Parcel Information Viewer. With this viewer you are able to zoom and pan the seamless parcel, terrain, and aerial photos for Boone County, MO. You can also use the search box above to quickly search for properties by owner's name, address, or parcel number or simply navigate the map and use the Identify tool to click on the map to view its owner information.

Please send us your comments and suggestions regarding this new mapping application

E-mail GIS

ATTENTION!!

These maps were prepared for the inventory of real property based on the utilization of deeds, plans, and/or supportive data. In addition, map files are frequently changed to reflect changes in boundaries, lot lines and other geographic features resulting from changes in ownership, development, and other causes. The existence, dimension, and location of features, as well as other information, should not be relied upon for any purpose without actual field verification. The County of Boone makes no warranty of any kind concerning the completeness or accuracy of information contained on these maps and assumes no liability or responsibility for the use or reuse of these maps by persons not affiliated with Boone County. Use of these maps by any person not affiliated with Boone County constitutes agreement by the user to assume full



MADE WITH beautiful.ai

Parcel Information Viewer

Zoom to Neighborhood | Zoom to Location

Print | Link | Map Legend | Help

Parcel Number, Owner's Name, or Property Address:

Cooksey

1680128070040001

Owner	COOKSEY BRIAN & REBEKAH FAMILY TRUST
Address	2991 W RIDLEY WOOD ST
City, State, Zip	COLUMBIA, MO 65203
School	COLUMBIA (C1)
Legal Description	HUNTERS RIDGE SD LOT 4
Lot Size	180.00 x 193.35
Irregular Shape	Y
Parcel	16-801-28-07-004.00 01

Full Real Estate Summary

Click plus icon above to view full real estate summary

Back to List

Parcel Data Current as of: 8/1/2026
Information Retrieved: 9/1/2026 1:39 PM CDT

MADE WITH beautiful.ai

Brian Cooksey in Columbia, MO

Age 40 / 1986 • ✓ Verified 2991 Ridley Wood St, Columbia, MO 65203

Brian A Cooksey, 40 years old, lives in Armstrong, MO. Data verified from public official sources.

Get Full Report

Sponsored by BeenVerified

Contact Information

See Brian Cooksey's current address and primary phone number.

ADDRESS

2991 Ridley Wood St, Columbia, MO 65203 +6

PHONE NUMBERS

(555) 555 - 0100

View Contact Info

Sponsored by Truthfinder

If this is you

Control Your Information
Monitor your public presence

Protect Your Family
Remove their data too

More Results for Brian Cooksey

BD Brian D Cooksey, 57
Saint Louis, MO

BS Brian S Cooksey, 60
Columbus, OH

BA Brian A Cooksey, 40
Columbia, MO

BD Brian D Cooksey, 63
Saint Louis, MO

BC Brian Cooksey
Columbia, MO

View more →

Data freshness

MADE WITH beautiful.ai

Brian Cooksey
in Columbia, MO (Missouri)

Age 40, Born May 1986
Lives in Columbia, MO
555-0100

@ Email Addresses
for Brian Cooksey in Columbia, MO

email @hotmail.com

MADE WITH beautiful.ai

oogle

Rock Bridge Cooksey

Boone County, MO · Choose area

AI Overview

The phrase "Rock Bridge Cooksey" points directly to students and student-athletes associated with **Rock Bridge High School** in Columbia, Missouri.

Depending on the context of your search, you are likely looking for one of the following individuals:

1. Ethan Cooksey (Cross Country / Track & Field)

- **Overview:** A prominent student-athlete from the Rock Bridge High School Class of 2024.
- **Achievements:** He was a key runner for the Rock Bridge Bruins cross country team. He is prominently featured in regional athletic databases, holding notable placement records on the Rock Bridge Team Records on Athletic.net and detailed career statistics on Ethan Cooksey's MoMileSplit Profile. MileSplit United States

2. Ellie Cooksey (Girls' Varsity Soccer)

- **Overview:** A younger student-athlete currently aligned with the Rock Bridge High School Class of 2029.
- **Achievements:** She plays sports for the high school, including girls' varsity soccer. You can track her athletic videos and high school recruitment progression directly via

Grad year of 2024 gives Ethan a likely birth year of 2005 - 2006

Grad year of 2029 gives Ellie a likely birth year of 2010 - 2011

MADE WITH beautiful.ai

ellie cooksey columbia mo

AI Mode | All | Images | News | Forums | Shopping | Videos | More | Tools

Hudl
https://www.hudl.com › profile

Ellie Cooksey

Watch **Ellie Cooksey's** videos and highlights on Hudl. More info: Rock Bridge High School - Girls' Varsity Soccer / Class of 2029 / **Columbia**, **MO**.

MileSplit United States
https://mo.milesplit.com › teams › roster

Columbia Jefferson MS - Roster

Columbia Jefferson MS. 713 Rogers Street; Columbia, MO USA. Website ... **Cooksey, Ellie**. f. 2029. Cox, Michael. m. 2030. Craig, Alexander. m. 2029. Creech ... Read more

Columbia Daily Tribune
https://www.columbiatribune.com › local › 2013/12/06

2013 Living Windows Festival

Dec 6, 2013 — **Ellie Cooksey**, 3, left, daughter of Brian and Rebekah of **Columbia**; and Eleanor Barhorst, 3, daughter of Frank and Tommi Barhorst of **Columbia** ... Read more

Ellie Cooksey daughter of Brian and Rebekah

3 in Dec, 2013

Birth year of 2010

MADE WITH beautiful.ai

INFORMATION GATHERED SO FAR

- **Brian**
  May, 1986
  Address
  Work Email
  Personal Email
  Phone
- **Beka**
  September, 1986
  Address
  Personal Email
  Phone
  Maiden Name
- **Ethan**
  Class of 2024, 21
- **Ellie**
  Class of 2029, 16
- **Liam**
  August Birthday, 11

MADE WITH
beautiful.ai

OPTIONS FOR ATTACK

Attack Brian's Account

We have the most info about him

We know he likely has Rock access

Account is likely monitored

Attack Beka's Account

We have a lot of info about her

If she has a login it's probably not monitored

She could have multiple emails, may not know which is in Rock

Attack Child's Account

Unlikely to have an account

We could potentially run an account takeover

Have less confirmed info

MADE WITH beautiful.ai

SECURITY SETTINGS FOR THIS EXAMPLE

Disable Duplicate Checking for the Following Protection Profiles

- [ ] Low
- [x] Medium
- [x] High
- [x] Extreme

Allow Merges of Account Protection Profile - High

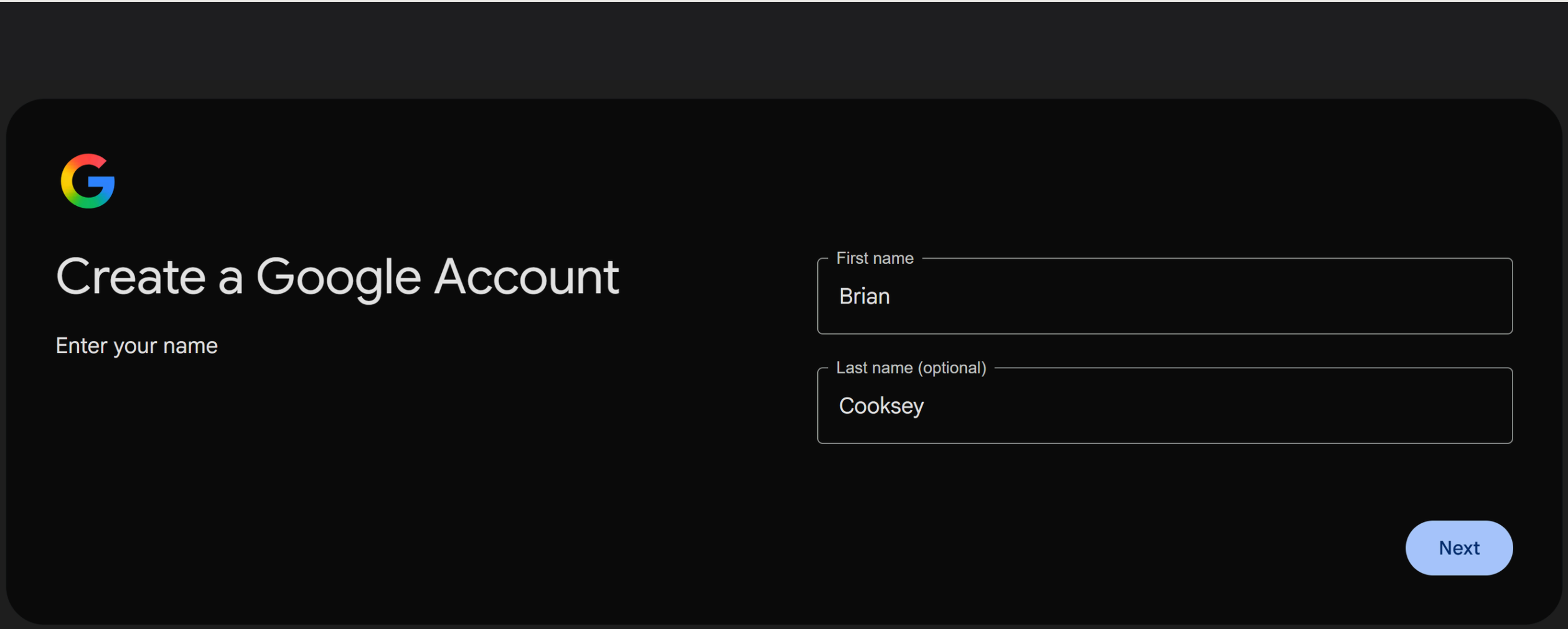
RSR - Data Integrity Worker

Disable Usage of Personal Tokens for the Following Protection Profiles

- [ ] Low
- [ ] Medium
- [ ] High
- [x] Extreme

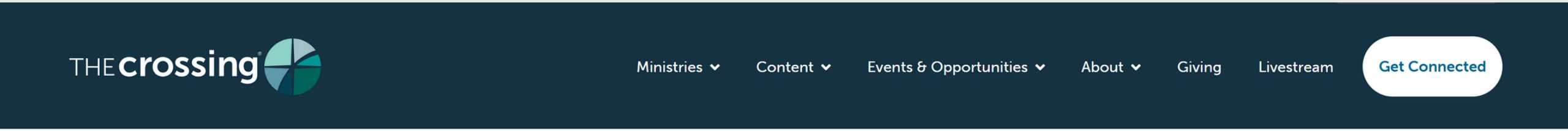
MADE WITH beautiful.ai

ANYONE CAN CREATE AN EMAIL



MADE WITH beautiful.ai

DO SOME REASONABLE ACTION FOR OUR RECORD SOURCE



Men's Fall Retreat - November 20-21, 2026

Congratulations Brian

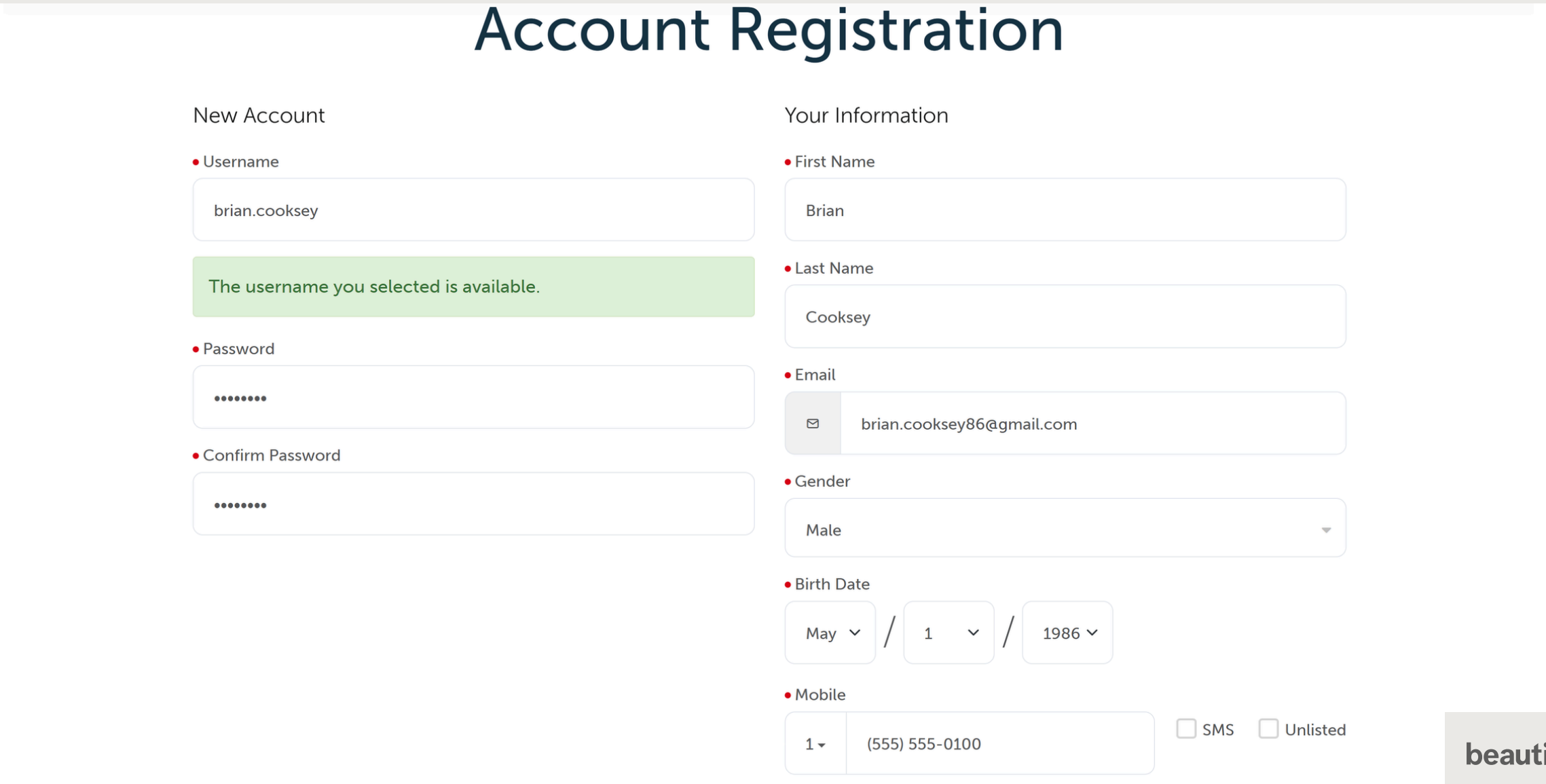
You have successfully registered the following registrant for Men's Fall Retreat - November 20-21, 2026:

- **Brian Cooksey**
  Lodging Accommodation:
  Would you prefer to stay for one or two nights in the lodge or in your tent? Lodge - 2 Nights : $295.00

A confirmation email has been sent to brian.cooksey86@gmail.com. If you have any questions, please contact Chris McKinney at chris.mckinney@thecrossingchurch.com.

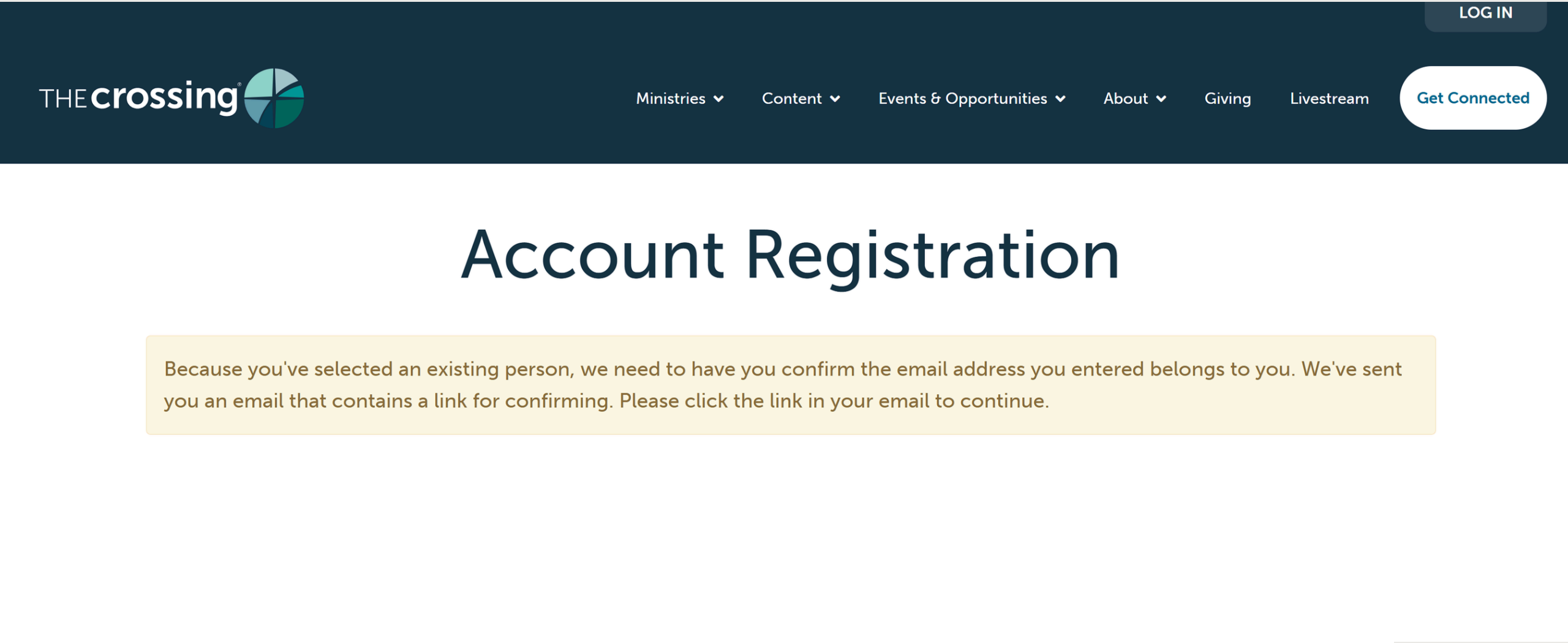
MADE WITH beautiful.ai

CREATE AN ACCOUNT



MADE WITH beautiful.ai

LINK IT TO THE REGISTRATION



MADE WITH beautiful.ai

CONFIRM THE ACCOUNT VIA EMAIL

Brian,

A new username and password was created for your account. Please confirm that you initiated this action.

If you did not create this account, you can delete it by clicking the button below.

Delete Account Confirm Account

MADE WITH beautiful.ai

MODIFY INFORMATION FROM PROFILE

Personal Information

Title

• First Name

Brian

• Last Name

Cooksey

Nick Name

Brian

Suffix

Birth Date

/ /

• Gender

Male

Contact Information

• Email Address

brian.cooksey@thecrossingchurch.com

Email Preference

All Emails Only Personalized Do Not Email

Home Address

Moved

United States

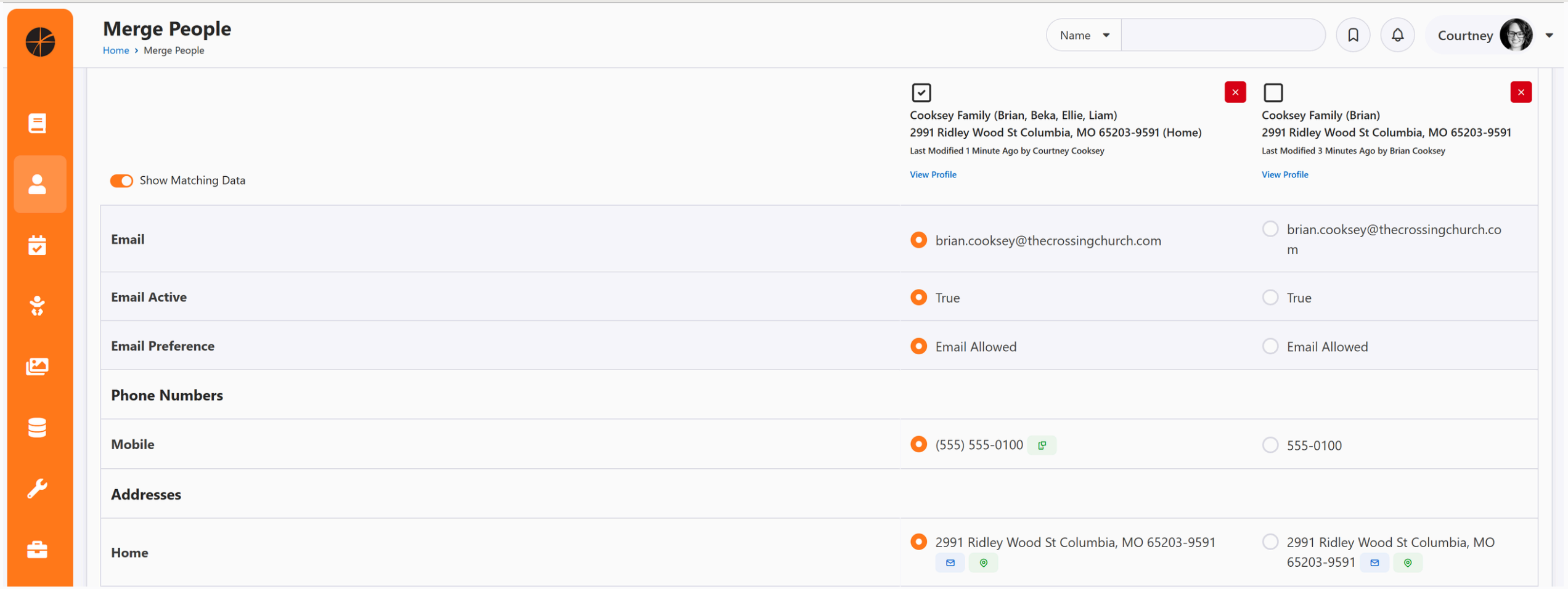
2991 Ridley Wood St

Columbia

MO

MADE WITH beautiful.ai

AVAILABLE DATA MATCHES DURING MERGE



MADE WITH beautiful.ai

ROCK'S WARNING ISN'T NECESSARILY HELPFUL

CRITICAL SECURITY ALERT: One or more of the records has a login. This could be an attempt to hijack the account. Additionally, this person will be prompted to reconfirm before they can log in.

ADDITIONALLY, ONE OR MORE OF THESE RECORDS IS A MEMBER OF A SECURITY ROLE WITH ELEVATED PRIVILEGES.

Critical Security Alert: One or more of the records has a login. This could be an attempt to hijack the account. Additionally, this person will be prompted to reconfirm before they can log in.

Additionally, one or more of these records is a member of a security role with elevated privileges.

MADE WITH beautiful.ai

MERGE > BAD ACTOR IS STAFF NOW

My Account

Brian Cooksey

40 years old
Male
Married

Contact Information

Home Address
2991 Ridley Wood St
Columbia, MO 65203-9591

Email
brian.cooksey@thecrossingchurch.com

Update Profile

Cooksey Family

Beka Cooksey

Account Info

Change Password

Giving

You currently have 2 giving profiles active.

Manage Giving

View History

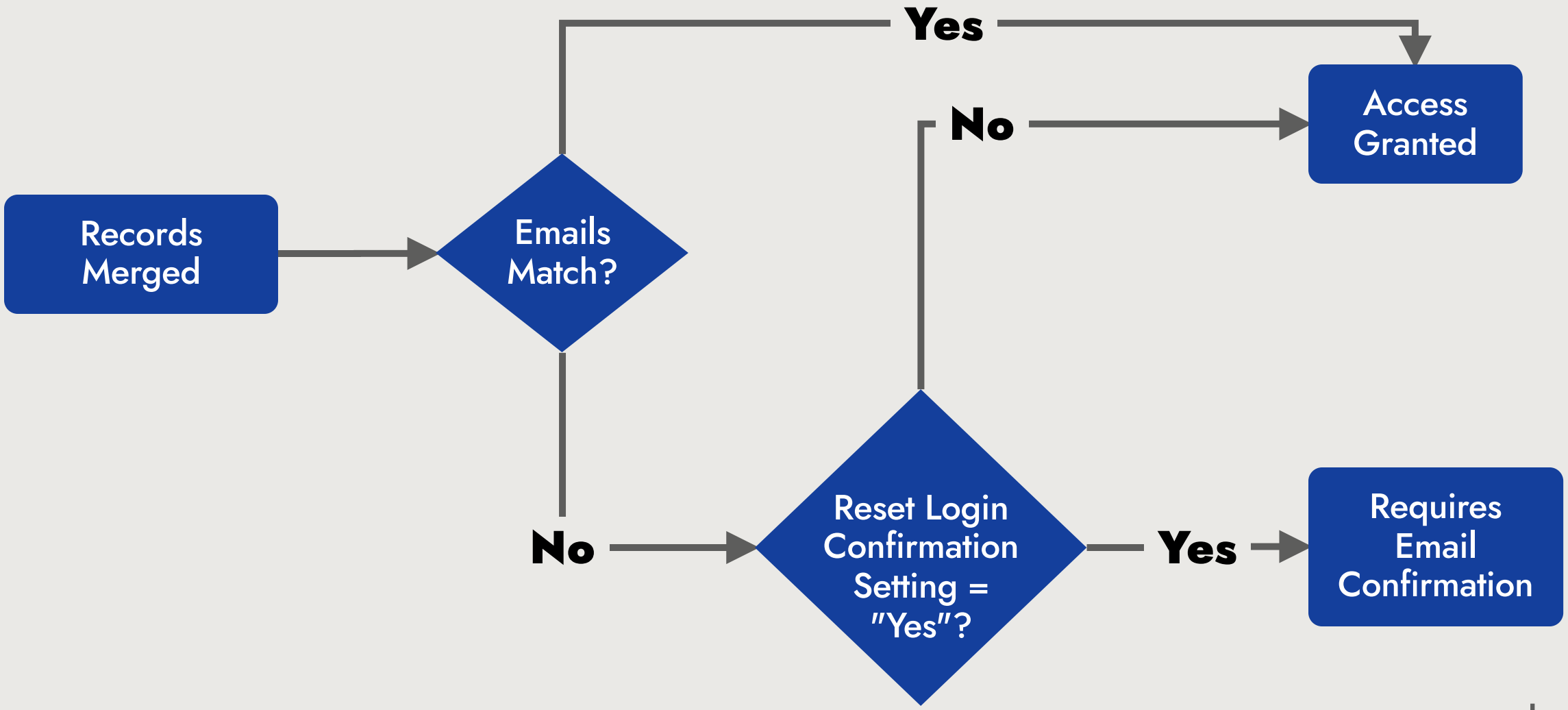
Give Now

Groups

Billings (Josh &

MADE WITH beautiful.ai

MERGE LOGIC



MADE WITH beautiful.ai

PREVENT MERGE ATTACKS

- **Staff Training and Awareness**
  Create and enforce policies about merging records with logins

- **Monitor Records with Security Grants**
  Any person record associated with some kind of elevated security should be regularly monitored for duplicate accounts

- **Monitor Changes to Contact Information**
  Changes to emails and phone numbers should be audited and confirmed with the person

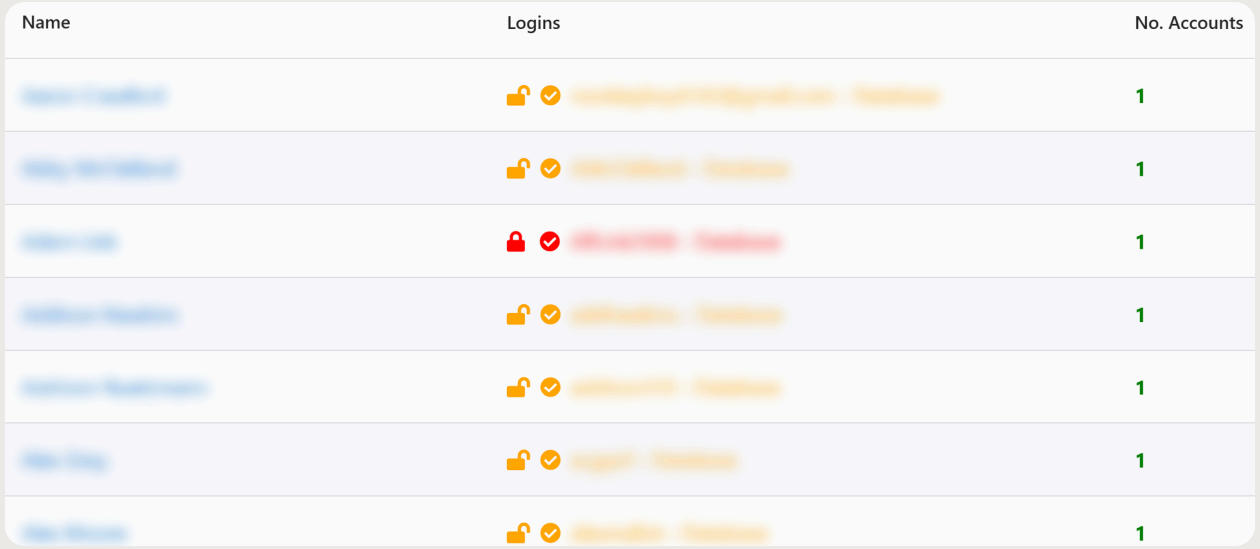
MADE WITH beautiful.ai

ADDITIONAL RECOMMENDATIONS FOR PRACTICAL APPLICATION

Logins	bcooksey	brian.cooksey
Security Notes		

Merge Records

Use a Helix (Lava) App to Display Login/Security Notes in Person Merge Grid



Use Data Views or Dynamic Data Blocks to create simple reports on the status of records with elevated access.

MADE WITH beautiful.ai

SPOUSE/FAMILY ATTACKS

HOW BAD SECURITY CONFIGURATIONS CAN LEAD TO DISASTER

MADE WITH
beautiful.ai

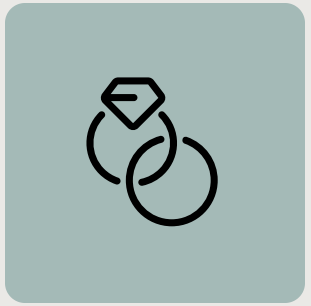
OPTIONS FOR ATTACK

Attack Brian's Account

We have the most info about him

We know he likely has Rock access

Account is likely monitored



Attack Beka's Account

We have a lot of info about her

If she has a login it's probably not monitored

She could have multiple emails, may not know which is in Rock

Attack Child's Account

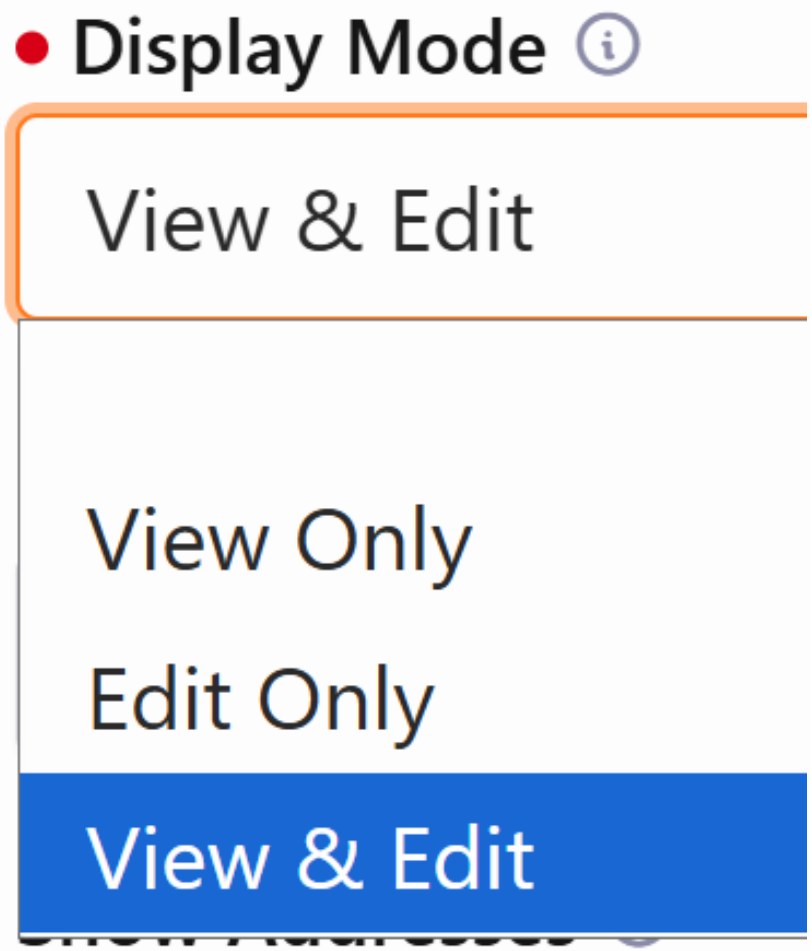
Unlikely to have an account

We could potentially run an account takeover

Have less confirmed info

MADE WITH beautiful.ai

BLOCK SETTINGS CAN LET YOU EDIT FAMILY MEMBERS INFO



Cooksey Family

Brian Cooksey

40 yrs old
Male
Married

Contact Info
brian.cooksey@thecrossingchurch.com

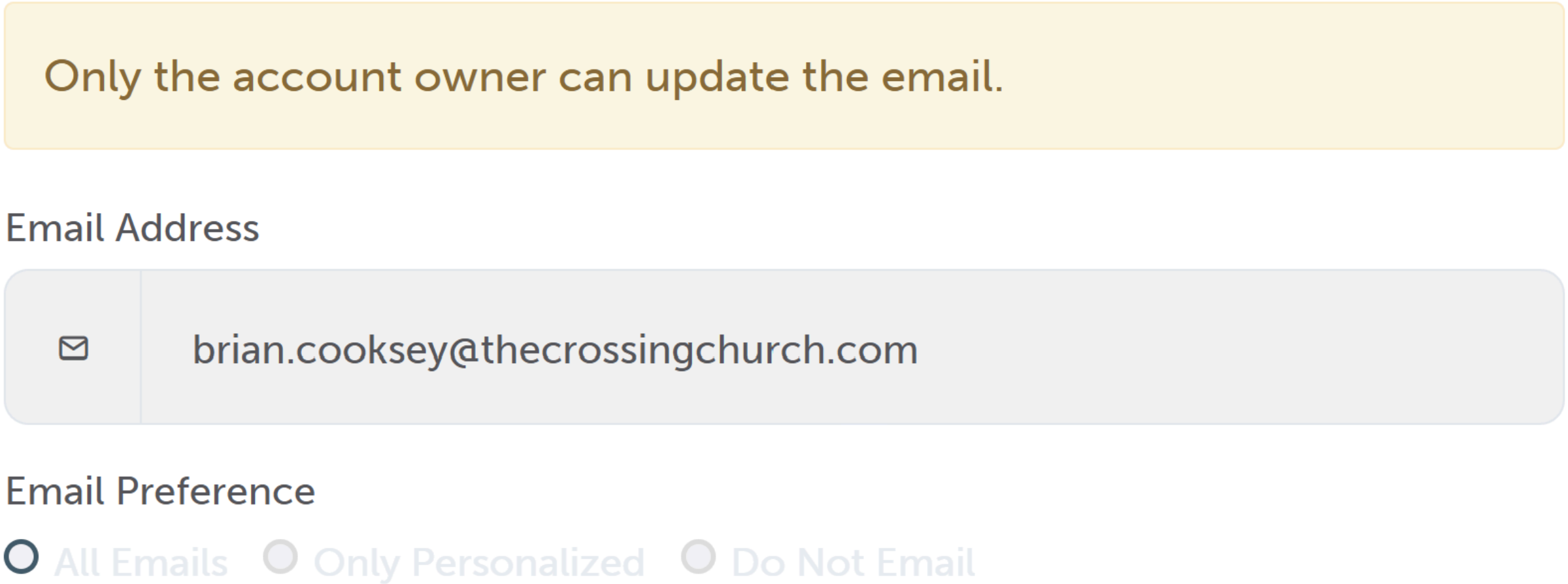
Ellie Cooksey

15 yrs old
Sophomore
Female
Single

Contact Info
elliecooksey@safety.netz

MADE WITH beautiful.ai

RECORDS WITH HIGH OR EXTREME PROFILES WILL BLOCK THIS



MADE WITH beautiful.ai

PREVENT SPOUSE/FAMILY ATTACKS

- Set the Display Mode to View Only
- Ensure all records with internal Rock access have High or Extreme Protection Profiles
- Ensure all records with saved payment information or access to sensitive information have High or Extreme Protection Profiles

  i.e. Group Leaders for Support Groups like AA

MADE WITH beautiful.ai

INJECTION ATTACKS

Slide Deck

REASONS WE SANITIZE USER INPUT

WE'RE GOING TO GET PRETTY TECHNICAL FOR THIS SECTION

MADE WITH
beautiful.ai

INJECTION ATTACKS OCCUR WHEN UNINTENDED CODE RUNS ON YOUR ROCK INSTANCE

SQL Injection

Unintended Queries and Commands executed on your database

Lava Injection

Unintended sections of Lava executed on your server

XSS

Cross-Site Scripting

Unintended code is displayed and executed in your Rock instance

MADE WITH beautiful.ai

PAGE PARAMETER + DYNAMIC DATA BLOCK

Search

Men

Filter Reset Filters

2 items

Group Name
20s Single Men - North Columbia
20s Single Men - Jeff City

50

MADE WITH beautiful.ai

SIMPLE QUERY TO FILTER GROUPS BASED ON SEARCH FIELD

```
{% assign search = 'Global' | PageParameter:'Search' %}
SELECT * FROM TestTable WHERE GroupName LIKE '%{{search}}%'
```

MADE WITH
beautiful.ai

SIMPLE QUERY TO FILTER GROUPS BASED ON SEARCH FIELD

```
{% assign search = 'Global' | PageParameter:'Search' %}
SELECT * FROM TestTable WHERE GroupName LIKE '%{{search}}%'
```

'; SELECT NickName, LastName from PERSON WHERE LastName = 'Cooksey'; SELECT '

MADE WITH beautiful.ai

WEBFORMS DYNAMIC DATA BLOCK RESULTS - 3 GRIDS

Id	Group Name
1	20s Single Men - North Columbia
2	20s Married Couples - Southwest Columbia
3	30s Single Co-ed - Northeast Columbia
4	20s Single Men - Jeff City

50 500 5,000 4 Items

Nick Name	Last Name
Betty	Cooksey
Brian	Cooksey
Brian	Cooksey
Courtney	Cooksey
Courtney	Cooksey
Darrell	Cooksey
Diana	Cooksey
Ellie	Cooksey
Ellie	Cooksey
Ethan	Cooksey
Gerald	Cooksey
Liam	Cooksey
Beka	Cooksey

50 500 5,000 13 Items

Column 1
%

50 500 5,000 1 Item

MADE WITH beautiful.ai

WEBFORMS DYNAMIC DATA BLOCK RESULTS - 3 GRIDS

Id	Group Name
1	20s Single Men - North Columbia
2	20s Married Couples - Southwest Columbia
3	30s Single Co-ed - Northeast Columbia
4	20s Single Men - Jeff City

50 500 5,000 4 Items

Nick Name	Last Name
Betty	Cooksey
Brian	Cooksey
Brian	Cooksey
Courtney	Cooksey
Courtney	Cooksey

Column 1
%

50 500 5,000 1 Item

MADE WITH beautiful.ai

OBSIDIAN DYNAMIC DATA BLOCK RESULTS - 1 GRID

Search

'; SELECT NickName AS Id, LastName AS GroupName FROM Person WHERE LastName = 'Cooksey'; SELECT '

Filter Reset Filters

4 items

Id	Group Name
1	20s Single Men - North Columbia
2	20s Married Couples - Southwest Columbia
3	30s Single Co-ed - Northeast Columbia
4	20s Single Men - Jeff City

50

MADE WITH beautiful.ai

WHAT IS ACTUALLY BEING RUN

```
SELECT * FROM TestTable WHERE GroupName LIKE '%';
SELECT NickName, LastName FROM Person WHERE LastName =
'Cooksey';
SELECT '%'
```

MADE WITH
beautiful.ai

WHAT IS ACTUALLY BEING RUN

```
SELECT * FROM TestTable WHERE GroupName LIKE '%';
SELECT NickName, LastName FROM Person WHERE LastName =
'Cooksey';
SELECT '%'
```

At first glance it seems the Obsidian version has stopped the attack

MADE WITH
beautiful.ai

WHAT IS ACTUALLY BEING RUN

```
SELECT * FROM TestTable WHERE GroupName LIKE '%';
SELECT NickName, LastName FROM Person WHERE LastName =
'Cooksey';
SELECT '%'
```

At first glance it seems the Obsidian version has stopped the attack

Reality is that while the Obsidian block limits to a single grid displayed

All three SQL statements are still executed

MADE WITH
beautiful.ai

A MORE NEFARIOUS INJECTION COULD ELEVATE ACCESS

'; UPDATE UserLogin SET PersonId = 1 WHERE UserName = 'hacker'; SELECT '

```
SELECT * FROM TestTable WHERE GroupName LIKE '%';
UPDATE UserLogin SET PersonId = 1 WHERE UserName = 'hacker';
SELECT '%'
```

MADE WITH
beautiful.ai

A MORE NEFARIOUS INJECTION COULD ELEVATE ACCESS

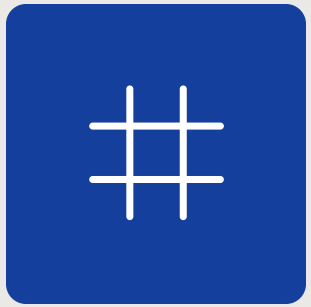
'; UPDATE UserLogin SET PersonId = 1 WHERE UserName = 'hacker'; SELECT '

```
SELECT * FROM TestTable WHERE GroupName LIKE '%';
UPDATE UserLogin SET PersonId = 1 WHERE UserName = 'hacker';
SELECT '%'
```

DOES THE DEFAULT ADMIN ADMIN ACCOUNT ON YOUR INSTANCE HAVE RSR - ADMINISTRATOR?

MADE WITH beautiful.ai

PREVENTING SQL INJECTION

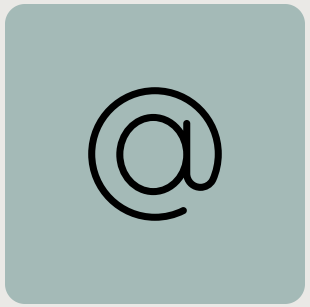


Cast Input to Non-Text Type

Run the **AsInteger** filter on your user input that should be numeric to prevent any additional text from being added to the query

SanitizeSql Filter

Use the **SanitizeSql** filter to escape single quotes in user input

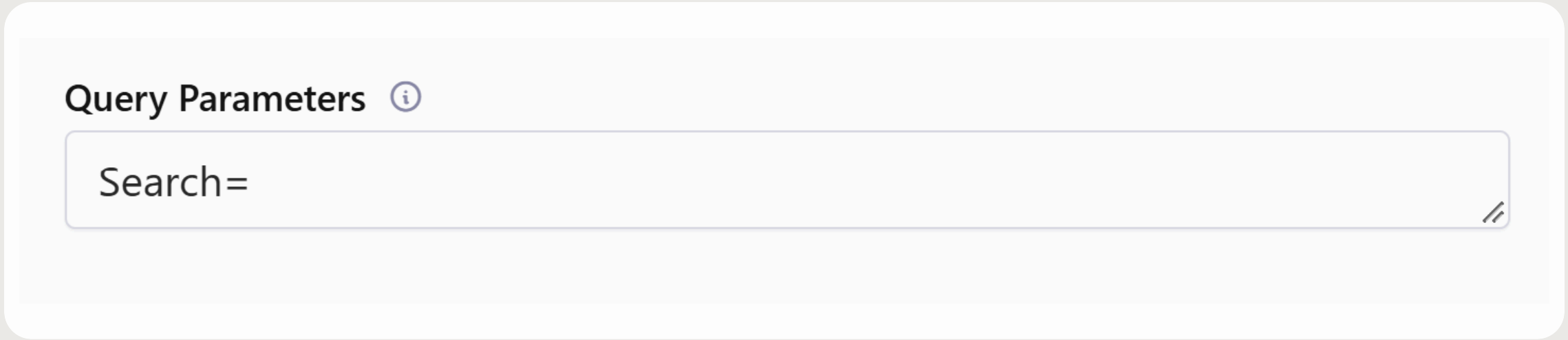


Parameterize Input

The gold standard for ensuring user input does not change the intention of the query

MADE WITH
beautiful.ai

USE THE QUERY PARAMETERS FIELD IN A DYNAMIC DATA BLOCK



- Comma Separated List of Variables you want
- name=value format
- name= to pull from url
- Available in query as @name

MADE WITH
beautiful.ai

USING VARIABLES IN THE DYNAMIC DATA QUERY

```
SELECT * FROM TestTable WHERE GroupName LIKE '%' + @Search + '%'
```

We can use the variables from the block settings without a declaration

```
DECLARE @Search VARCHAR(50) = '20s';
SELECT * FROM TestTable WHERE GroupName LIKE '%' + @Search + '%'
```

We can also create our own variables to use
(helpful for Ids that change between environments)

MADE WITH
beautiful.ai

USING VARIABLES IN THE LAVA SQL TAG

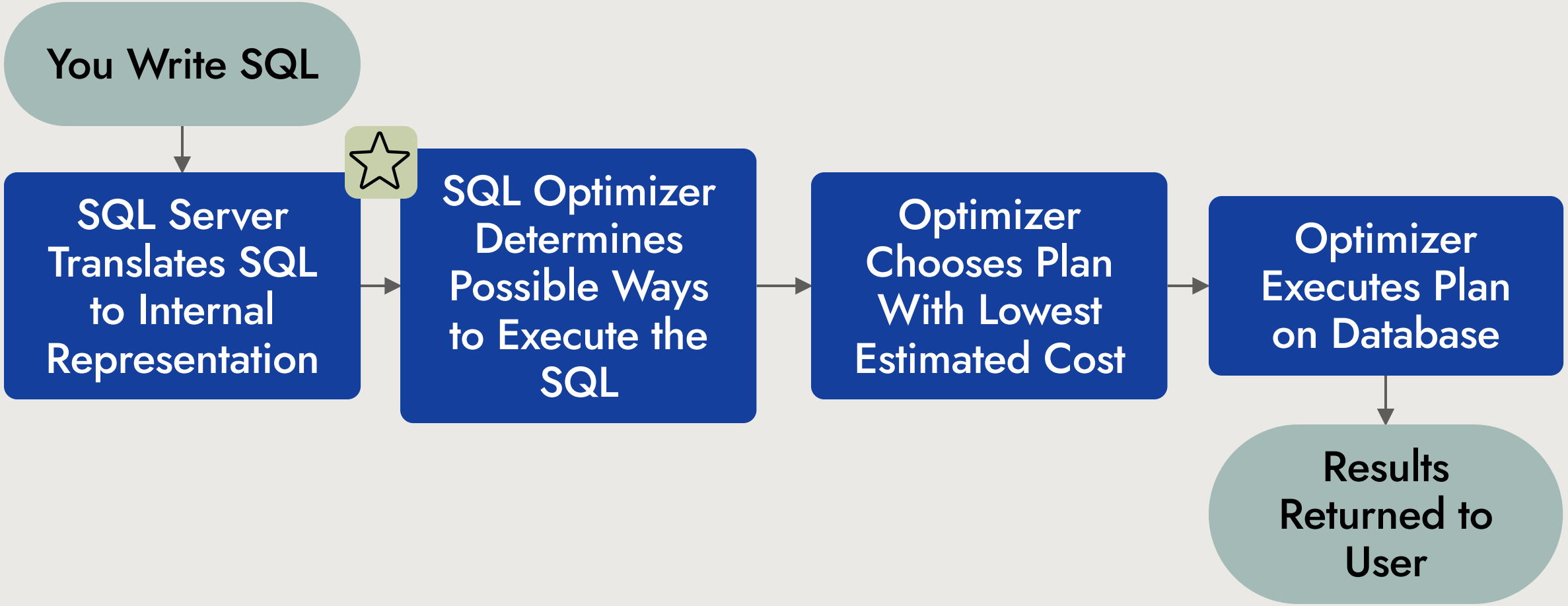
```
{% assign search = 'Global' | PageParameter:'Search' %}
{% sql search:'{{search}}' %}
    SELECT * FROM TestTable WHERE GroupName LIKE '%' + @search +
'%'
{% endsql %}
```

- Added to the opening sql tag
- name:'value' format
- Available in query as @name

MADE WITH beautiful.ai

UNDERSTANDING THE DIFFERENCE BETWEEN PREVENTION METHODS

The SQL Query Lifecycle



MADE WITH beautiful.ai

UNDERSTANDING THE DIFFERENCE BETWEEN PREVENTION METHODS

Casting/Sanitizing

User Input is present for the entire lifecycle

Is Included when the server makes the Query Plan

Parameterizing

User Input is only present during execution

Not included when the server makes the Query Plan

MADE WITH beautiful.ai

THE DIFFERENCE LIES IN HOW THE SERVER CREATES A PLAN

- **Sanitized**
  If the sanitization isn't done properly, the injected query will be what the server builds a plan on
  The server will think we want to run two queries and an update
- **Parameterized Query**
  Database knows we only want to run a single SELECT Query
  No possible way to change that

MADE WITH beautiful.ai

IDENTIFYING USER INPUT

'; Drop Table #TestTable; SELECT '

Search

'; SELECT NickName AS Id, LastName AS GroupName FROM Person WHERE LastName = 'Cooksey'; SELECT '

Filter Reset Filters

MADE WITH beautiful.ai

DATA THAT CAME FROM THE USER AT ANY POINT SHOULD BE CONSIDERED DANGEROUS

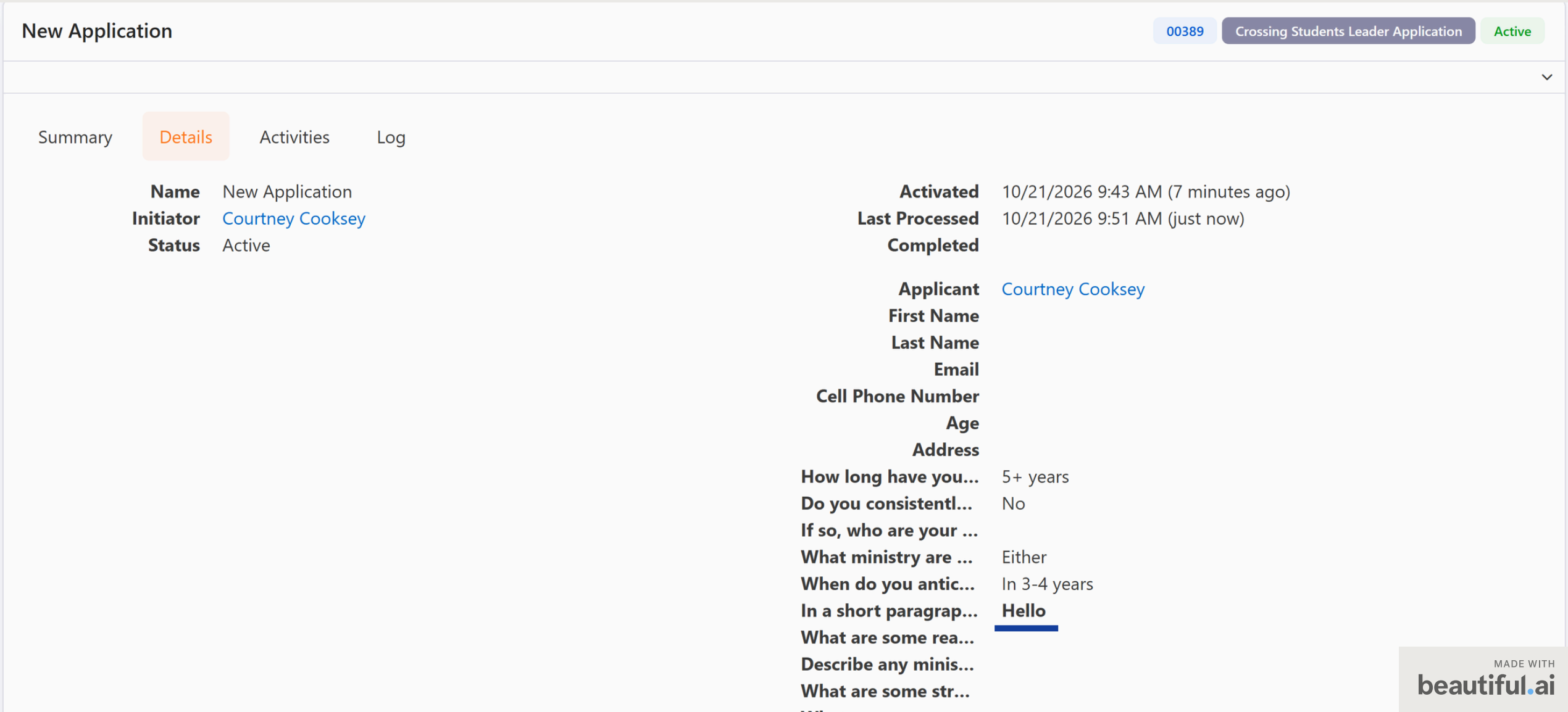
```
SELECT * FROM Person
WHERE NickName = '{{ CurrentPerson.NickName }}'
```

MADE WITH
beautiful.ai

PLACES IN ROCK RENDER DATABASE FIELDS AS HTML

MADE WITH beautiful.ai

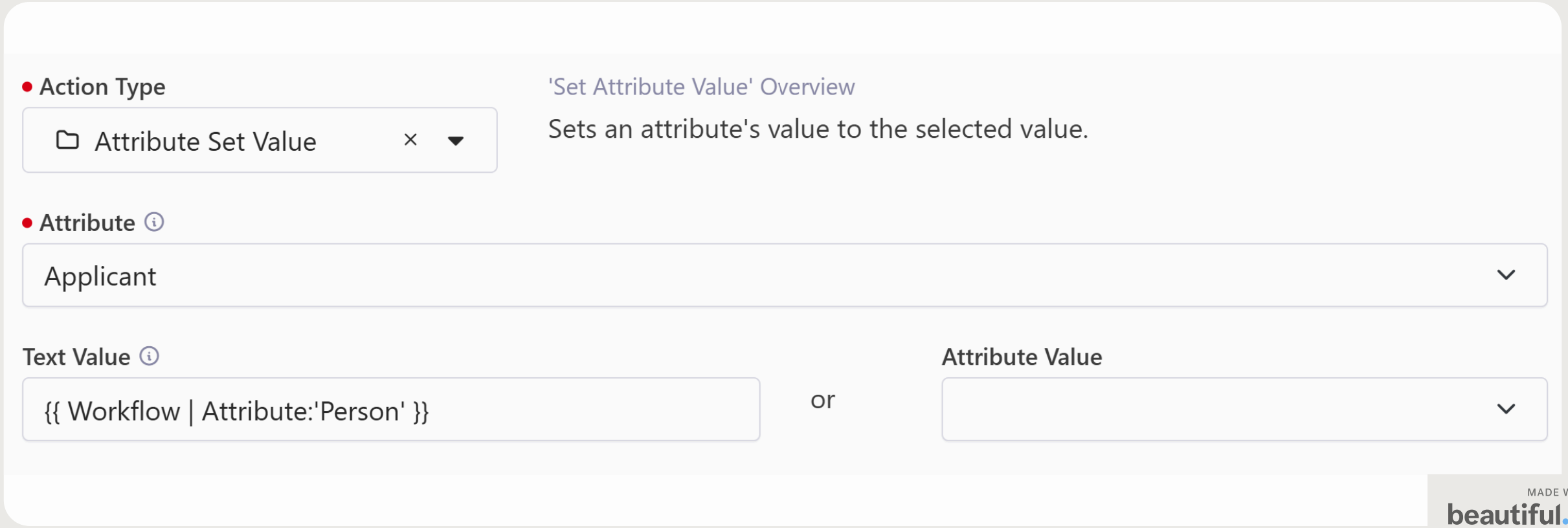
PLACES IN ROCK RENDER DATABASE FIELDS AS HTML



MADE WITH beautiful.ai

CERTAIN WORKFLOW ACTIONS PROCESS LAVA ON USER INPUT

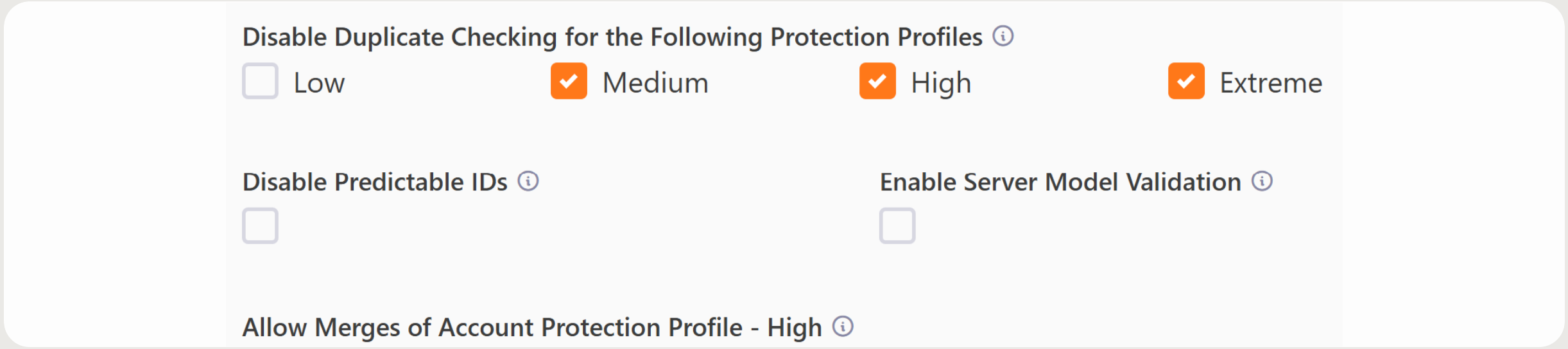
The text or attribute to set the value from. {{ Lava }}

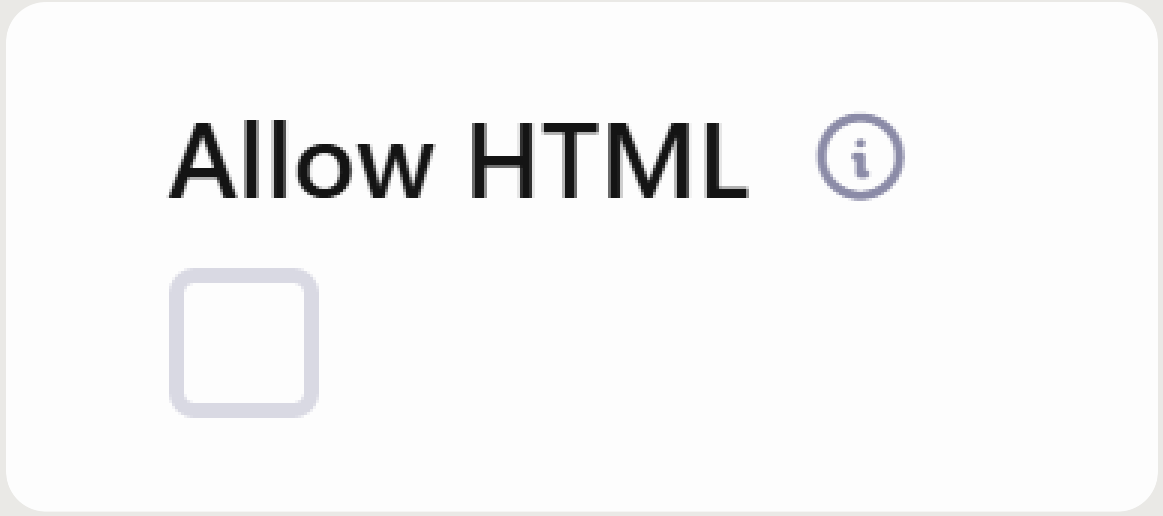


MADE WITH beautiful.ai

PREVENT THIS BY CONFIGURING SETTING FOR SERVER MODEL VALIDATION

You can allow HTML and Lava Separately in the Attribute Configuration





MADE WITH beautiful.ai

PROTECTING YOUR ROCK INSTANCE

Slide Deck

SETTINGS, CONFIGURATION, AND BEST PRACTICES

MADE WITH
beautiful.ai

SECURITY SETTINGS

Duplicate Checking

At Minimum: Disable for High/Extreme Accounts

Best: Disable for all Records with Logins

Impersonation Tokens

At Minimum: Disable for Extreme Accounts

Best: Disable for all Records with Internal Rock access or access to sensitive information

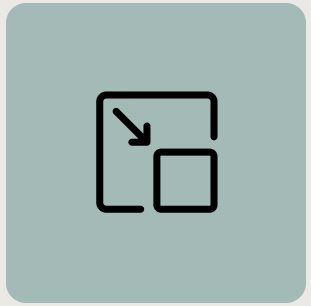
Passwordless Sign-In

At Minimum: Disable for Extreme Accounts

Best: Disable for all Records with Internal Rock access or access to sensitive information

MADE WITH beautiful.ai

GENERAL CONFIGURATION



Least Privilege

Don't give people more access than they absolutely need to do their job

Enforce Policies with Security Rules

Good security isn't easy

Assign granular roles and make sure the auth in Rock reflects that

Lock or Remove Unnecessary Pages

Rock migrations come with a lot of examples for new blocks and pages

Your responsibility to audit and update access

MADE WITH beautiful.ai

MONITORING

Multiple Accounts

At Minimum: Monitor staff records for number of logins

Best: Monitor staff, staff families, and volunteer records for number of logins

Contact Information

At Minimum: Monitor staff records for changes to email or phone number

Best: Monitor staff, staff families, and volunteer records

Suspicious Activity

- Failed Login Attempts
- IP Location
- Phishing Attempts

MADE WITH beautiful.ai

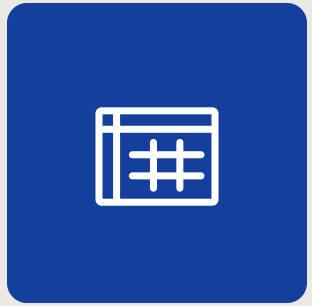
POLICIES

Merging Records

- Checking Logins
- Checking Contact Info
- Checking Security Notes

Impersonation

- Who is it allowed for?
- Token restrictions (Time, Uses, Page)



Data

- Exporting Data from Rock
- Sharing Data

MADE WITH
beautiful.ai

QUESTIONS?

SLIDE DECK/TAKEAWAYS

courtney@thecrossingchurch.com

If you need help converting your SQL to pure SQL and not using Lava ask in the develop channel on Rocket Chat

Feel free to DM me or tag me

MADE WITH beautiful.ai